

RESEARCH ARTICLE

An anonymous and secure biometric-based enterprise digital rights management system for mobile environment

Dheerendra Mishra¹, Ashok Kumar Das^{2*} and Sourav Mukhopadhyay¹¹ Department of Mathematics, Indian Institute of Technology, Kharagpur 721 302, India² Center for Security, Theory and Algorithmic Research, International Institute of Information Technology, Hyderabad 500 032, India

ABSTRACT

Internet-based content distribution facilitates an efficient platform to sell the digital content to the remote users. However, the digital content can be easily copied and redistributed over the network, which causes huge loss to the right holders. On the contrary, the digital rights management (DRM) systems have been introduced in order to regulate authorized content distribution. Enterprise DRM (E-DRM) system is an application of DRM technology, which aims to prevent illegal access of data in an enterprise. Earlier works on E-DRM do not address anonymity, which may lead to identity theft. Recently, Chang *et al.* proposed an efficient E-DRM mechanism. Their scheme provides greater efficiency and protects anonymity. Unfortunately, we identify that their scheme does not resist the insider attack and password-guessing attack. In addition, Chang *et al.*'s scheme has some design flaws in the authorization phase. We then point out the requirements of E-DRM system and present the cryptanalysis of Chang *et al.*'s scheme. In order to remedy the security weaknesses found in Chang *et al.*'s scheme, we aim to present a secure and efficient E-DRM scheme. The proposed scheme supports the authorized content key distribution and satisfies the desirable security attributes. Additionally, our scheme offers low communication and computation overheads and user's anonymity as well. Through the rigorous formal and informal security analyses, we show that our scheme is secure against possible known attacks. Furthermore, the simulation results for the formal security analysis using the widely accepted Automated Validation of Internet Security Protocols and Applications tool ensure that our scheme is also secure. Copyright © 2015 John Wiley & Sons, Ltd.

KEYWORDS

digital rights management systems; content distribution; authorization; mobile user; anonymity; AVISPA; security

*Correspondence

Ashok Kumar Das, Center for Security, Theory and Algorithmic Research, International Institute of Information Technology, Hyderabad 500 032, India.

E-mail: iitkgp.akdas@gmail.com; ashok.das@iiit.ac.in

1. INTRODUCTION

The advances in network technology have made the Internet a user-friendly and efficient way of digital data transmission. The Internet provides a scalable platform for the trade of digital content (DC; music, movies, document, image, etc.). It facilitates easy access of multimedia content at low cost to the remote users. However, the DC can be easily copied and redistributed over the network without degradation in the content quality. This causes rampant piracy that results in huge revenue loss to the right holders. Digital rights management (DRM) systems are developed in response to the rapid increase in the piracy of commercially marketed digital products [1]. The purpose of

this technology is to regulate the content consumption so that unauthorized access and illegal redistribution of multimedia content can be restricted.

DRM has emerged as a solution for copyright protection. It broadly refers to the set of policies, techniques, and tools, which manages the access control on the DCs [2]. Contents' security is based on the encryption of DCs, and the access of these contents is controlled by using the digital license [3]. The core concept of DRM is to provide secure content delivery infrastructure. Many organizations proposed models and standards for distributing DC over the public network, a few are the Open Mobile Alliance, Moving Picture Experts Group, Internet Streaming Media Alliance, Coral, Digital Media Project, and

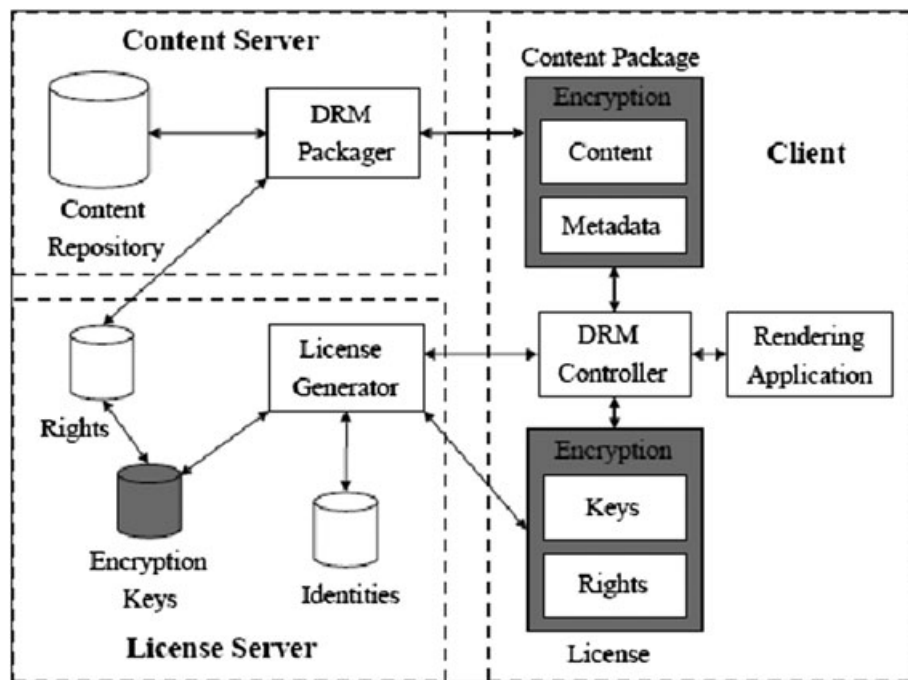


Figure 1. A typical digital rights management (DRM) system architecture (source: [4,5]).

Advanced Access Control System. A typical DRM system architecture is shown in Figure 1. There are three major components: the content server (CS), the license server (LS), and the client, which have been discussed in the following:

- The CS consists of the actual content, services (information about several products) that the content provider (CP) is responsible to distribute, and functionality to prepare content for a DRM-based distribution.
- The LS manages the licensing information such as the identity of the user or device that wants to exercise rights concerning the content, identification of the content to which the rights apply, and specification of those rights.
- The client resides on the user's side and supplies the various functionalities such as DRM controller, the rendering (authorizing) application as well as the user's authentication service.

For more details on DRM, one can refer to [4,5].

In an enterprise, the databases are of critical business importance for organizations, and therefore, the company could suffer potential losses if an unauthorized user obtains the secret files, for example, account balances and bank statements for financial institutes and personal health records in health institutions. The information theft in the enterprise may cause reputation damage, identity theft, and even threaten the viability of the organization [6,7]. A survey conducted by [8] in 400 organizations, which admitted to having experienced 5794 incidents of excessive

privilege and access control rights and 6244 incidents of employee negligence, discussed the internal security incidents. This shows the need of a secure and authorized access of the enterprise data. Enterprise DRM (E-DRM) systems have been designed to control access of corporate documents rather than to control the consumer media such as movies or songs. E-DRM is an application of DRM system that protects the confidential information of an enterprise from illegal access [9]. The e-companies rely on E-DRM need to protect their confidential information and data.

Portability feature of mobile devices increases its applicability in day to day work. Mobile devices are also being used to access confidential data. Many times, the office employees access the files from the company database via a mobile device. In recent years, several researchers have presented secure E-DRM systems for securing confidential database [10–16]. However, most of the existing DRM schemes for confidentiality of documents have high computation overheads, which are not compatible with mobile device because of the following reasons: (i) small screen and functional key area; (ii) limited battery life, browsing capability, storage space, and computing power; (iii) user-unfriendly interface; and (iv) higher error probability of data transaction and storage.

1.1. Related work

In recent years, the efforts have been played to design suitable E-DRM schemes for mobile environment. In 2008, Chen [17] proposed an E-DRM scheme for mobile device. This scheme has low computation overhead that makes

it more suitable for mobile devices. It is integrated with hardware information, one-time password, and digital certificate mechanism in such a way that persistent protection, authentication, integrity, portability, and security concerns can be addressed.

Later, Chang *et al.* [18] discovered some flaws in Chen's scheme. They demonstrated that Chen's scheme has insecure content key distribution as an adversary can easily compute symmetric key and the mobile user (MU) cannot identify the tampering of message. They also identified some redundant computations in the authorization phase of Chen's scheme. To erase these security flaws, Chang *et al.* proposed an improved E-DRM scheme for mobile environment. Their improved scheme can easily identify the tampering with the transmitted messages. Additionally, their scheme has no redundant computation. However, recently, Chang *et al.* [19] found that Chang *et al.*'s scheme [18] has security weaknesses. Chang *et al.* [19] showed that Chang *et al.*'s scheme [18] does not withstand stolen device attack. Further, before accessing the DC, a MU has to acquire digital certificate. Moreover, an MU cannot change his or her device without the server assistant. These drawbacks make Chang *et al.*'s scheme [18] unfriendly and insecure. Chang *et al.* [19] introduced an anonymous identity-based authentication scheme for E-DRM system to erase the certificate management and to protect user's anonymity. Their scheme has the merits of low computation and user's anonymity. Unfortunately, we identify that their scheme is vulnerable to insider attack and off-line password-guessing attack. Moreover, an adversary can learn the acquired content identity in the system and can make the usage profile of content trade, which an enterprise may want to keep confidential. Concerning the aforementioned weaknesses, an efficient and secure content key distribution mechanism for E-DRM systems is further proposed.

Guo and Chang [20] proposed an efficient authenticated group key distribution scheme based on the generalized Chinese remainder theorem [21]. Their method is also based on the secret-sharing scheme. Later, Liu *et al.* [22] presented a group key distribution scheme for E-DRM. Their approach uses the concept of the secret-sharing scheme and the generalized Aryabhata remainder theorem [23]. The main advantage of their scheme is that only authorized group members can share a common session key among other members in the same group. Further, different groups of enterprise members can also use their group session keys in order to obtain the corresponding digital information simultaneously. Their scheme is also efficient and secure against outsider and insider attacks.

Huang *et al.* [24] presented a privacy-preserving DRM scheme, which uses homomorphic encryption and proxy re-encryption in the cloud-computing environment. In their framework shown in Figure 2, the key server (KS) is responsible for the generation of the public/private key pair for the CP as well as user. The CP also generates the re-encryption key for authorized user and sends it to the LS. In addition, the KS generates random assistant key and distributes it to the CP, and the CP also generates random content main key. The CP encrypts the DC with the content encryption key, and then outsources the encrypted DC to the centralized CS. The service provider sends user's license acquisition message to the LS. In their scheme, the DC is outsourced to the centralized CS in cloud computing only once. Their scheme thus avoids expensive content re-encryption tasks. In addition, their scheme achieves privacy preserving by allowing the users to stay anonymous to the KS and service provider. Zou *et al.* [25] presented a cloud-based mobile DRM scheme with Subscriber Identity Module (SIM) card, called Phosphor. They designed the License State Word that is located in a SIM card. They used the License State Word in order

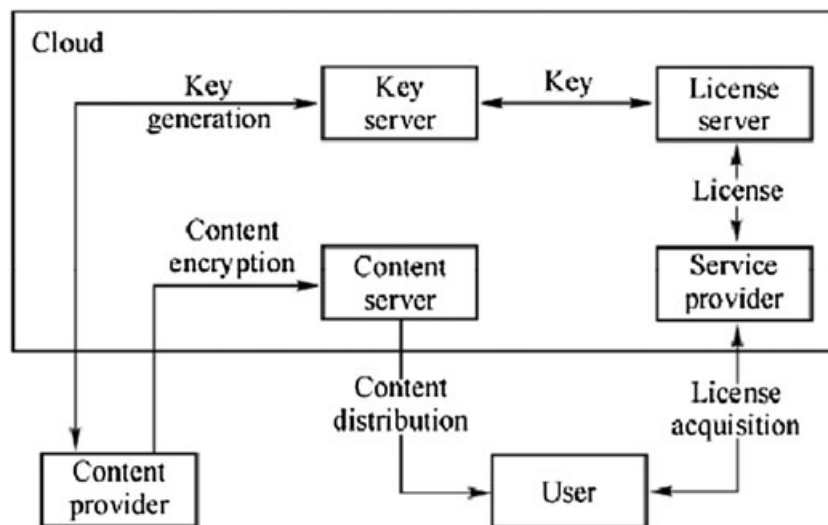


Figure 2. Cloud-based digital rights management framework in Huang *et al.*'s scheme (source: [24]).

to ensure the license's integrity such that Phosphor can protect the licenses from an attacker. Later, Wang *et al.* [26] proposed an efficient cloud-based SIM DRM scheme for the mobile Internet. However, in their approach, there are some optimization opportunities, such as Extensible Markup Language (XML) compression. Petric and Sorge [27] proposed a privacy-preserving scheme for DRM in the cloud-computing environment. In their approach, the users stay anonymous to software providers and computing centers.

1.2. Threat model

We assume that an adversary can retrieve all the sensitive information stored in the mobile device of a legal user, once it is lost or stolen by that adversary. Furthermore, we use the Dolev–Yao threat model [28], in which the two communicating parties communicate over an insecure public channel. We use the similar threat model for our scheme where the communicating channels are insecure and the endpoints cannot in general be trustworthy. We assume that an attacker may be a legitimate user. Although the server is considered as a trusted party, we still assume that an insider of that server may be also an attacker, and thus, the privileged-insider attack is possible. In addition, we assume that an MU can choose an easy-to-remember password, which may be a low-entropy password.

1.3. Our contributions

Our contributions in this paper are listed as follows:

- We first point out the security flaws in the recently proposed Chang *et al.*'s E-DRM scheme, namely (i) it is vulnerable to off-line password-guessing attack, (ii) it does not withstand insider attack, and (iii) it has some design flaws in the authorization phase.
- To overcome the security flaws found in Chang *et al.*'s scheme, we present a secure and efficient E-DRM scheme suitable for mobile environment.
- The proposed scheme protects the MU's anonymity.
- Through the rigorous informal and formal security analyses, we show that our scheme can successfully prevent different kinds of network attacks.
- In addition, the simulation results for the formal security analysis using the widely accepted Automated Validation of Internet Security Protocols and Applications (AVISPA) tool ensure that our scheme is secure.
- Our scheme is also efficient in computation as compared with other existing schemes.

1.4. Organization of the paper

The rest of the paper is organized as follows. In Section 2, we discuss some basic mathematical preliminaries, which are helpful for describing and analyzing Chang *et al.*'s scheme [19] and our proposed scheme. In Section 3, we present in brief the review of Chang *et al.*'s scheme [19]

and then point out the security weaknesses of their scheme. In Section 4, we present a dynamic identity-based remote user authentication mechanism for DRM system for the mobile device. In Section 5, through the rigorous formal security analysis using the widely accepted Burrows-Abadi-Needham (BAN) logic and informal security analysis, we show that our scheme has the ability to defend various known attacks. In Section 6, we simulate our scheme for the formal security verification using the widely accepted AVISPA tool to show that our scheme is also secure. In Section 7, we compare the performance of our scheme with other related schemes. Finally, the conclusion is drawn in Section 8.

2. MATHEMATICAL PRELIMINARIES

In this section, we discuss in brief the existing fuzzy extractor methods to verify the personal biometrics of a user.

2.1. Biometrics verification

A biometric system is a pattern recognition system [29–31] that operates by acquiring biometric data from an individual, extracting a feature set from the acquired data, and then comparing the extracted feature set against the template set in the database. Biometric verification allows one to confirm or establish an individual's identity. Several advantages of using biometric keys (e.g., fingerprints, faces, irises, hand geometry, and palm prints) over the low-entropy passwords are as follows [32]: (i) biometric keys cannot be lost or forgotten, (ii) they are very difficult to copy or share, (iii) they are hard to forge or distribute, (iv) they cannot be guessed easily, and (v) someone's biometrics is not easy to break than others.

2.2. Biometrics fuzzy extractor

Let $\mathcal{M} = \{0, 1\}^v$ denote a finite dimensional metric space, which consists of the biometric data points. Let $d : \mathcal{M} \times \mathcal{M} \rightarrow \mathbb{Z}^+$ be a distance function, which can be used to calculate the distance between two points based on the metric chosen, where $\mathbb{Z}^+$ is the set of all positive integers.

A fuzzy extractor $(\mathcal{M}, l, t)$ extracts a nearly l -bit random string σ_i from its biometrics input B_i in an error-tolerant way, where t is the error tolerance threshold [33]. If an input B'_i changes but remains close to B_i , the extracted σ_i remains the same. To recover σ_i from the biometrics input B'_i , a fuzzy extractor also produces an auxiliary string τ_i , where σ_i remains uniformly random for a given τ_i .

Definition 1. The fuzzy extractor $(\mathcal{M}, l, t)$ can be described by the following two probabilistic and deterministic algorithms [33–35]:

- *Gen*: This probabilistic algorithm takes a biometric $B_i \in \mathcal{M}$ as input, and then outputs a key data $\sigma_i \in \{0, 1\}^l$ and also a public reproduction parameter τ_i . In other words, $\{\sigma_i, \tau_i\} = \text{Gen}(B_i)$.

- *Rep*: This deterministic algorithm takes a noisy biometric $B'_i \in \mathcal{M}$ and a public parameter τ_i related to B_i , and then reproduces the biometric key data σ_i . In other words, $Rep(B'_i, \tau_i) = \sigma_i$ provided that the condition $d(B_i, B'_i) \leq t$ holds.

The fuzzy extractor $(\mathcal{M}, l, t)$ is efficient, if both *Gen* and *Rep* algorithms run in polynomial time in representation size of a point in $\mathcal{M}$.

3. REVIEW AND CRYPTANALYSIS OF CHANG ET AL.'S SCHEME

In this section, we first present in brief the overview of Chang *et al.*'s scheme [19] and then point out the security weaknesses on their scheme. The notations listed in Table I are used for describing Chang *et al.*'s scheme as well as our scheme in the next section in this paper.

3.1. Description of Chang *et al.*'s scheme

Chang *et al.* [19] proposed an improvement over the scheme presented in [18]. Their scheme is composed

Table I. Notations used in this paper.

Notation	Description
MU	Mobile user
CS	Content server
LS	License server
AA	Authorization authority
PS	Package server
ID_{MU}	Identity of MU
ID_{DC}	Identity of digital content DC
$KEY_{ID_{DC}}$	Randomly generated symmetric key by PS
AID	Anonymous identity chosen by MU
Req	Registration request message of MU in Chang <i>et al.</i> 's scheme [19]
PW_{MU}	Unique password of MU
T_{MU}	Timestamp generated by MU
T_{AA}	Timestamp generated by AA
T_{LS}	Timestamp generated by LS
X	Master key of LS in our scheme/secret key of AA in Chang <i>et al.</i> 's scheme [19]
IMEI	Unique international mobile equipment identification number assigned to each mobile terminal
$Sym.Enc_K(\cdot)/$ $Sym.Dec_K(\cdot)$	Symmetric encryption/ decryption using key K
$H(\cdot)$ & $F(\cdot)$	One-way hash functions
DRM-AP	DRM-enabled application
$\oplus$	Bitwise XOR operation
$\parallel$	String concatenation operation

DRM, digital rights management.

of three phases: package phase, registration phase, and authorization phase, which are described in the following subsections. Additionally, the E-DRM adopts the six authorities in order to regulate the services, which are (i) DC author; (ii) package server (PS); (iii) CS; (iv) LS; (v) authorization authority (AA); and (vi) mobile consumer or MU.

3.1.1. Package phase.

Packaging of DC is performed by the PS. The DC is provided by the authors. The PS completes the packaging of DCs and facilitates the content distribution with the help of the LS and AA. The description of the packaging phase is as follows:

- Step 1. PS generates a symmetric key $KEY_{ID_{DC}}$ randomly and then encrypts the DRM format file DC using the generated key $KEY_{ID_{DC}}$ to $E(DC) = Sym.Enc_{KEY_{ID_{DC}}}(DC)$. PS also generates the file header CH and generates two signatures for $E(DC)$ and CH using its private key as $Sig_{PS}(E(DC))$ and $Sig_{PS}(CH)$, respectively. Finally, PS creates an E-DRM-formatted file as shown in Figure 3 and provides them to the CS. The E-DRM formatted file has two parts: the content header (CH) and the encrypted content C . The CH contains the content identity (CID), which is the identity of a DC , the type of the DRM-enable application $DRM-AP_{type}$ used for integrating the existing applications and indicating suitable applications to access the DC , the identity of the decryption key KEY_{CID} , some attributes (Attributes), the digital signature (Sig_C) of C signed by the PS , and the uniform resource locator of the AA .
- Step 2. PS signs the content identity ID_{DC} and content key $KEY_{ID_{DC}}$ by using its private key and obtains $Sig_{PS}(ID_{DC}, KEY_{ID_{DC}})$. PS provides $(ID_{DC}, KEY_{ID_{DC}}, Sig_{PS}(ID_{DC}, KEY_{ID_{DC}}))$ to LS via a secure channel.
- Step 3. Upon receiving the files, CS verifies the PS's signature using the PS's public key. If the verification holds, the CS stores the E-DRM-formatted file in its database and publishes the directory of the file.
- Step 4. Upon receiving the key seed, the LS verifies signature $Sig_{PS}(ID_{DC}, KEY_{ID_{DC}})$ using the PS's public key. If the signature is verified, the LS stores $(ID_{DC}, KEY_{ID_{DC}})$ in its database. Note that the key seed is the initial random seed number generated by the AA .

3.1.2. Registration phase.

This phase has the following steps:

- Step 1. MU selects his or her chosen identity ID_{MU} , password PW_{MU} , and anonymous identity AID . MU then sends the registration request

Content identity	Type of the DRM enable application ($DRM-AP_{type}$)	Identity of the decryption key (KEY_{CID})
Attributes	Signature of the encrypted content (Sig_C)	Authorization authority (URL)
Encrypted digital content (C)		

Figure 3. File structure of the enterprise digital rights management-formatted file (source: [17]). URL, uniform resource locator.

Mobile user (MU)	Authentication authority (AA)	License server (LS)
$\langle ID_{MU}, PW_{MU}, AID, Req \rangle$		
(via a secure channel)	$\langle H(AID \oplus X) \oplus PW_{MU} \rangle$	
	(via a secure channel)	
	$\langle AID, H(AID \oplus X) \rangle$	
	(via a secure channel)	

Figure 4. Summary of the registration phase of Chang *et al.*'s scheme.

- $\langle ID_{MU}, PW_{MU}, AID, Req \rangle$ to AA via a secure channel.
- Step 2. Upon receiving the registration request, AA verifies ID_{MU} and AID . If both ID_{MU} and AID are correct and unregistered, AA then computes $H(AID \oplus X)$ and $H(AID \oplus X) \oplus PW_{MU}$, and sends the message $\langle H(AID \oplus X) \oplus PW_{MU} \rangle$ to MU. MU stores the value $H(AID \oplus X) \oplus PW_{MU}$ in his or her mobile device.
- Step 3. AA sends AID and $H(AID \oplus X)$ to LS via a secure channel. LS stores these information in its database.

This phase is summarized in Figure 4.

3.1.3. Authorization phase.

This phase consists of the following steps:

- Step 1. MU can download the DC using DRM-AP. To access the downloaded file, MU inputs AID and PW_{MU} . The DRM-AP computes $H(AID \oplus X) \oplus PW_{MU} \oplus PW_{MU} = H(AID \oplus X)$.
- Step 2. DRM-AP generates a random number r_i and computes i -th one-time password $P_{MU_i} = H(H^i(AID \oplus X) \parallel T_{MU} \parallel ID_{DC}) \oplus r_i$. It also computes $C_{MU_i} = H(r_i \parallel IMEI)$, where i stands for i -th authorization phase. MU sends the message $\langle i, msg_{req}, T_{MU}, ID_{DC}, P_{MU_i}, C_{MU_i}, AID, IMEI \rangle$ to AA.
- Step 3. Upon receiving the message, AA verifies the time delay in message transmission. If it is valid, AA computes $r'_i = P_{MU_i} \oplus H(H^i(AID \oplus X) \parallel T_{MU} \parallel ID_{DC})$ and verifies whether $H(r'_i \parallel IMEI) = C_{MU_i}$ holds. If the verification does not hold, AA terminates the session. Otherwise, AA computes $P_{AA_i} = H(H^i(AID \oplus X) \parallel T_{AA} \parallel ID_{DC}) \oplus r'_i$ and $C_{AA_i} = H(r'_i \parallel IMEI \parallel AID)$. AA sends the message $\langle ID_{DC}, AID, IMEI, T_{AA}, P_{AA_i}, C_{AA_i} \rangle$ to LS.

- Step 4. Upon receiving the message in Step 3, LS achieves $H(AID \oplus X)$ corresponding to AID . LS computes $r''_i = P_{AA_i} \oplus H(H^i(AID \oplus X) \parallel T_{AA} \parallel ID_{DC})$ and verifies if the condition $H(r''_i \parallel IMEI \parallel AID) = C_{AA_i}$ holds. If the verification holds, LS computes $P_{LS_i} = H(H^i(AID \oplus X) \parallel T_{LS} \parallel r'_i) \oplus KEY_{ID_{DC}}$ and $C_{LS_i} = H(ID_{DC} \parallel KEY_{ID_{DC}} \parallel r'_i)$. LS then sends the message $\langle AID, P_{LS_i}, C_{LS_i}, T_{LS} \rangle$ to MU.
- Step 5. Upon receiving the message in Step 4, MU achieves the content key $KEY'_{ID_{DC}} = P_{LS_i} \oplus H(H^i(AID \oplus X) \parallel T_{LS} \parallel r'_i)$. MU then verifies if the condition $H(ID_{DC} \parallel KEY'_{ID_{DC}} \parallel r_i) = C_{LS_i}$ holds. If the verification holds, the content key is authenticated, and then the DC can be decrypted by using key $KEY'_{ID_{DC}}$.

This phase is summarized in Figure 5.

3.2. Cryptanalysis of Chang *et al.*'s scheme

In this section, we show that Chang *et al.*'s scheme still has the following three security drawbacks.

3.2.1. Privileged-insider attack.

Sometimes a consumer (MU) uses the same password for several accounts, because it is difficult to remember several distinct passwords for different accounts. When a consumer submits his or her password in its original form to the server, a malicious insider can always have an opportunity to know the consumer's password. It increases the possibility of illegal access of the consumer's accounts, which are protected with the same passwords. Note that in Chang *et al.*'s scheme, during the registration phase (Section 3.1.2, Step 1) the MU sends the registration request $\langle ID_{MU}, PW_{MU}, AID \rangle$ to AA via a secure channel, where the password PW_{MU} is in plaintext format. As a

Mobile user (MU)	Authentication authority (AA)	License server (LS)
Inputs AID and PW_{MU} . Computes $H(AID \oplus X) \oplus PW_{MU}$ $\oplus PW_{MU} = H(AID \oplus X)$. Generates r_i and computes $P_{MU_i} = H(H^i(AID \oplus X) T_{MU} ID_{DC}) \oplus r_i$, $C_{MU_i} = H(r_i IMEI)$. $\langle i, msg_{req}, T_{MU}, ID_{DC}, P_{MU_i}, C_{MU_i}, AID, IMEI \rangle$ (via a public channel)	Verifies T_{MU} . Computes $r'_i = P_{MU_i} \oplus H(H^i(AID \oplus X) T_{MU} ID_{DC})$. Verifies if $H(r'_i IMEI) = C_{MU_i}$? If it holds, computes $P_{AA_i} = H(H^i(AID \oplus X) T_{AA} ID_{DC}) \oplus r'_i$, $C_{AA_i} = H(r'_i IMEI AID)$. $\langle ID_{DC}, AID, IMEI, T_{AA}, P_{AA_i}, C_{AA_i} \rangle$ (via a public channel)	Computes $r''_i = P_{AA_i} \oplus H(H^i(AID \oplus X) T_{AA} ID_{DC})$ and verifies if $H(r''_i IMEI AID) = C_{AA_i}$? If it holds, computes $P_{LS_i} = H(H^i(AID \oplus X) T_{LS} r''_i) \oplus KEY_{ID_{DC}}$, $C_{LS_i} = H(ID_{DC} KEY_{ID_{DC}} r''_i)$. $\langle AID, P_{LS_i}, C_{LS_i}, T_{LS} \rangle$ (via a public channel to MU)
Computes $KEY_{ID_{DC}} = P_{LS_i} \oplus H(H^i(AID \oplus X) T_{LS} r_i)$. Verifies if $H(ID_{DC} KEY_{ID_{DC}} r_i) = C_{LS_i}$? If it holds, content key is authenticated.		

Figure 5. Summary of the authorization phase of Chang *et al.*'s scheme.

result, a malicious insider of AA can easily know the password PW_{MU} of a legal user MU . Thus, Chang *et al.*'s scheme fails to protect the privileged-insider attack.

3.2.2. Off-line password-guessing attack.

An adversary E can successfully perform the off-line password-guessing attack on Chang *et al.*'s scheme using the extracted value $H(AID \oplus X) \oplus PW_{MU}$ from the stolen mobile device of a legal mobile user MU and the intercepted message $\langle i, msg_{req}, T_{MU}, ID_{DC}, P_{MU_i}, C_{MU_i}, AID, IMEI \rangle$ as follows:

- Step 1. E guesses a password PW^* and computes $H(AID \oplus X) \oplus PW_{MU} \oplus PW^* = H(AID \oplus X)^*$ and $P_{MU_i}^* \oplus H(H^i(AID \oplus X)^* || T_{MU} || ID_{DC}) = r_i^*$.
- Step 2. E verifies whether $C_{MU_i} = H(r_i^* || IMEI)$ holds or not.
- Step 3. If the verification succeeds, E identifies that PW^* is the correct consumer MU 's password PW_{MU} . Otherwise, E repeats from Step 1.

It is thus clear that in Chang *et al.*'s scheme, an adversary E can successfully derive a correct low-entropy password using the off-line password-guessing attack.

3.2.3. Flaws in authorization phase.

In Chang *et al.*'s scheme, the mobile device executes the session without verifying the correctness of inputs. This causes extra communication and computation overheads. Moreover, the consumer may not identify the correct reason behind the session termination as in the following four cases, and the session is terminated at the same step:

- Input correct identity and incorrect password.
- Input incorrect identity and correct password.
- Input incorrect identity and incorrect password.
- Message impersonation attack.

Case 1. Suppose the consumer (MU) inputs correct anonymous identity AID and incorrect password $PW^* (\neq PW)$. The session is executed as follows:

- DRM-AP computes $H(AID \oplus X) \oplus PW \oplus PW^* \neq H(AID \oplus X)$ as $PW \neq PW^*$.
- DRM-AP generates a random number r_i and computes i -th one-time password $P_{MU_i}^* = H(H^i(AID \oplus X) \oplus PW \oplus PW^* || T_{MU} || ID_{DC}) \oplus r_i$ and $C_{MU_i} = H(r_i || IMEI)$. MU sends the message $\langle i, msg_{req}, T_{MU}, ID_{DC}, P_{MU_i}^*, C_{MU_i}, AID, IMEI \rangle$ to AA.

- Upon receiving the message, AA verifies the time delay in message transmission. The verification holds as the MU uses fresh timestamp. AA computes $r'_i = P_{MU_i}^* \oplus H(H^i(AID \oplus X) \parallel T_{MU} \parallel ID_{DC}) \neq r_i$ as $H^i(AID \oplus X) \neq H^i(AID \oplus X) \oplus PW \oplus PW^*$.
- AA verifies if the condition $H(r'_i \parallel IMEI) = C_{MU_i}$ holds. The verification does not hold as $r_i \neq r'_i$. Thus, AA terminates the session.

Case 2. Let the consumer input incorrect anonymous identity $AID^* (\neq AID)$, but a correct password PW_{MU} . However, the mobile device does not verify the correctness of input identity and executes the session as follows:

- DRM-AP computes $H(AID \oplus X) \oplus PW_{MU} \oplus PW_{MU} = H(AID \oplus X)$.
- DRM-AP generates a random number r_i and computes i -th one-time password $P_{MU_i} = H(H^i(AID \oplus X) \parallel T_{MU} \parallel ID_{DC}) \oplus r_i$ and $C_{MU_i} = H(r_i \parallel IMEI)$. Finally, MU sends message $\langle i, msg_{req}, T_{MU}, ID_{DC}, P_{MU_i}, C_{MU_i}, AID^*, IMEI \rangle$ to AA.
- Upon receiving the message, AA verifies the time delay in message transmission. The verification holds as MU uses fresh timestamp. AA then computes $r'_i = P_{MU_i} \oplus H(H^i(AID^* \oplus X) \parallel T_{MU} \parallel ID_{DC}) \neq r_i$ as $H(AID^* \oplus X) \neq H(AID \oplus X)$.
- AA verifies if the condition $H(r'_i \parallel IMEI) = C_{MU_i}$ holds. The verification does not hold as $r_i \neq r'_i$. Therefore, AA terminates the session.

Case 3. If the consumer inputs both incorrect anonymous identity $AID^* (\neq AID)$ and incorrect password $PW^* (\neq PW)$, the session is executed as follows:

- DRM-AP computes $H(AID \oplus X) \oplus PW \oplus PW^* \neq H(AID \oplus X)$ as $PW \neq PW^*$.
- DRM-AP generates a random number r_i and computes i -th one-time password $P_{MU_i}^* = H(H^i(AID \oplus X) \oplus PW \oplus PW^* \parallel T_{MU} \parallel ID_{DC}) \oplus r_i$ and $C_{MU_i} = H(r_i \parallel IMEI)$. MU sends the message $\langle i, msg_{req}, T_{MU}, ID_{DC}, P_{MU_i}^*, C_{MU_i}, AID^*, IMEI \rangle$ to AA.
- Upon receiving the message, AA verifies the time delay in message transmission. The verification also holds as MU uses fresh timestamp. AA computes $r'_i = P_{MU_i}^* \oplus H(H^i(AID^* \oplus X) \parallel T_{MU} \parallel ID_{DC}) \neq r_i$ as $H^i(AID^* \oplus X) \neq H^i(AID \oplus X) \oplus PW \oplus PW^*$.
- AA verifies if $H(r'_i \parallel IMEI) = C_{MU_i}$. The verification does not hold as $r_i \neq r'_i$.
- AA terminates the session as the message verification does not hold.

Case 4. An adversary E can also intercept and modify the log-in message, which causes the session termination in the similar way as discussed in the other cases, as follows:

- DRM-AP computes $H(AID \oplus X) \oplus PW \oplus PW = H(AID \oplus X)$.

- DRM-AP generates a random number r_i and computes i -th one-time password $P_{MU_i} = H(H^i(AID \oplus X) \parallel T_{MU} \parallel ID_{DC}) \oplus r_i$ and $C_{MU_i} = H(r_i \parallel IMEI)$. MU sends the message $\langle i, msg_{req}, T_{MU}, ID_{DC}, P_{MU_i}, C_{MU_i}, AID, IMEI \rangle$ to AA.
- E intercepts MU's message and generates a random number r_E . E computes $P_{MU_i}^* = P_{MU_i} \oplus r_E$ and replaces the message $\langle i, msg_{req}, T_{MU}, ID_{DC}, P_{MU_i}, C_{MU_i}, AID, IMEI \rangle$ with $\langle i, msg_{req}, T_E, ID_{DC}, P_{MU_i}^*, C_{MU_i}, AID, IMEI \rangle$ and sends it to AA, where T_E is the current timestamp of the adversary E 's system.
- Upon receiving the message, AA verifies the time delay in message transmission. The verification holds as E uses current timestamp. AA computes $r'_i = P_{MU_i}^* \oplus H(H^i(AID^* \oplus X) \parallel T_E \parallel ID_{DC}) \neq r_i$ as $T_E \neq T_{MU}$.
- AA verifies if $H(r'_i \parallel IMEI) = C_{MU_i}$. The verification does not hold as $r_i \neq r'_i$. Therefore, AA terminates the session.

In all the cases, the session is terminated in the same step. Therefore, a consumer (MU) may not identify the real reason of session failure because of the following points: (i) in case of incorrect identity and correct password input, a consumer may think that he or she has entered wrong password, (ii) in case of correct identity and wrong password input, a consumer may think that he or she has entered wrong identity, (iii) in case of correct identity and password input, if the message impersonation attack occurs, a consumer may think that he or she entered incorrect identity or wrong password. It is clear from all the facts that in case of the session termination, it may be difficult for a consumer (MU) to correctly identify mistake and may consider his or her correct password as a wrong password. Additionally, the inefficiency of the mobile device to verify the correctness of the input identity and password also causes extra communication and computation overheads.

4. THE PROPOSED SCHEME

In this section, we present an enhanced enterprise DRM scheme for the content distribution to the remote users in order to withstand the security pitfalls found in Chang *et al.*'s scheme.

We use the same notations listed in Table I for describing our scheme. The proposed scheme comprises of four phases, namely (i) package phase, (ii) registration phase, (iii) content key acquisition phase, and (iv) password and biometric update phase. First, the packaging server (PS) encrypts the DC and facilitates the content distribution with the help of the CS and LS. A new user first downloads the DRM-AP in his or her mobile device and then registers his or her device in the system. A registered user can acquire the content key and access the content.

As in Chang *et al.*'s scheme [19], instead of using IMEI, the anonymous identity, password, and biometrics are used

in our scheme in the authentication process. As a result, the MU can freely change his or her mobile device under any circumstances.

In our scheme, we assume that all the network entities PS , CS , LS , and the mobile user MU 's device are synchronized with their clocks as in [17–19]. If the time synchronization becomes a problem, one can also use the random nonces instead of timestamps in our scheme. The description of each phase is given in the succeeding text.

4.1. Registration phase

In order to access the E-DRM documents, an MU first installs the DRM-AP in his or her mobile device. Then, he or she completes the registration of the mobile device in the system. The description of registration phase is given in the following:

Step R1. The mobile user MU selects a unique identity ID_{MU} and a password PW_{MU} of his or her choice. Further, MU imprints his or her personal biometrics B_{MU} at the sensor of his or her mobile device.

Step R1.1. MU also generates a random 1024-bit-large number r .

Step R1.2. MU applies the $Gen(\cdot)$ fuzzy generator function on the input biometrics B_{MU} to produce the biometric data key σ_{MU} and a public reproduction parameter τ_{MU} as $Gen(B_{MU}) = (\sigma_{MU}, \tau_{MU})$.

Step R1.3. After that, MU computes the masked (pseudo) password $W = H(PW_{MU} || r || ID_{MU} || \sigma_{MU})$.

Step R1.4. MU then sends the registration request message $\langle ID_{MU}, W \rangle$ to LS via a secure channel.

Step R2. Upon receiving the registration request in Step R1, LS does the following:

Step R2.1. LS verifies the format of identity ID_{MU} . If this verification holds, LS generates a random 1024-bit-large number u .

Step R2.2. LS computes $K_{MU} = H(ID_{MU} || u || X)$ and then $Y_{MU} = K_{MU} \oplus W$, where X is a secret symmetric key of LS .

Step R2.3. LS also computes $DID_{MU} = \text{Sym.Enc}_X(ID_{MU} || u)$.

Step R2.4. LS then sends Y_{MU} and DID_{MU} to MU via a secure channel.

Step R3. MU stores both Y_{MU} and DID_{MU} in his or her mobile device. MU computes $r^* = r \oplus H(\sigma_{MU} || ID_{MU})$ and $Z_{MU} = H(PW_{MU} || r || \sigma_{MU})$. MU then stores τ_{MU} , t , r^* and Z_{MU} into his or her mobile device.

Note that in our scheme, r is not directly stored in the mobile device, instead of which r^* is stored in that device. Also, the mobile device does not store ID_{MU} directly. Finally, the mobile device of the user MU contains the information $\{Y_{MU}, DID_{MU}, Z_{MU}, r^*, \tau_{MU}, t\}$. The registration phase of our scheme is summarized in Figure 6.

4.2. Package phase

Packaging of content is performed by the PS , which is provided by the authors of the generated DC. The PS encrypts the DC and associates the CH with the encrypted content, and then facilitates the distribution of this DC with the help of LS and CS . The description of the packaging phase consists of the following steps:

Step P1. PS generates a random symmetric key $KEY_{ID_{DC}}$ and encrypts the digital content DC using key $KEY_{ID_{DC}}$ as $E(DC) = \text{Sym.Enc}_{KEY_{ID_{DC}}}(DC)$. PS also associates a header CH with each encrypted content, where the header includes content information and packager signature.

Mobile user (MU)	Secure channel	Registration server (LS)
Selects r , ID_{MU} and PW_{MU} . Imprints B_{MU} and computes $W = H(PW_{MU} r ID_{MU} \sigma_{MU})$.	$\langle ID_{MU}, W \rangle$	Verifies ID_{MU} . If verification holds, computes $K_{MU} = H(ID_{MU} u X)$, $Y_{MU} = K_{MU} \oplus W$, $DID_{MU} = \text{Sym.Enc}_X(ID_{MU} u)$.
Stores Y_{MU} , DID_{MU} in the device. Computes $r^* = r \oplus H(\sigma_{MU} ID_{MU})$, $Z_{MU} = H(PW_{MU} r \sigma_{MU})$. Stores r^* , Z_{MU} , τ_{MU} , t in the device.	$\langle Y_{MU}, DID_{MU} \rangle$	

Figure 6. Summary of the registration phase. LS , license server.

- Step P2. Once the content packaging is finished, the *PS* provides the content key seed to the *LS* via a secure channel. Moreover, *PS* provides the packaged content and content information to the *CS*, where the key seed is the initial random seed number generated by the *AA*.
- Step P3. Upon receiving the packaged content, the *CS* uploads the packaged content on the media server and displays the content information on the website.
- Step P4. Upon receiving the key seed, the *LS* securely stores the content key and provides the content key to the authorized users.

4.3. Content key acquisition phase

To access the DC on his or her mobile device, the *MU* downloads the DC from the media server. However, to access the DC, the *MU* needs the content key. To achieve the license, a registered user first needs to download the packaged content and then establish the authorized session with the *LS*. Once the user's verification holds, the *LS* issues the content key. The content key acquisition phase of our scheme is summarized in Figure 7. The description of this phase is given in the following:

- Step C1. *MU* inputs his or her identity ID_{MU} and password PW_{MU} in the mobile device. After that, *MU* imprints the biometrics B_{MU}^* at the sensor of the mobile device.

- Step C1.1. The DRM-AP computes $\sigma_{MU}^* = Rep(B_{MU}^*, \tau_{MU})$ using the $Rep(\cdot)$ fuzzy extractor function and stored τ_{MU} in the mobile device.

- Step C1.2. The DRM-AP further computes $r' = r^* \oplus H(\sigma_{MU}^* || ID_{MU})$, and then $Z_{MU}^* = H(PW_{MU} || r' || \sigma_{MU}^*)$.

- Step C1.3. The DRM-AP checks the condition $Z_{MU}^* = Z_{MU}$. If it does not hold, the password and biometrics verification fails, and the session is terminated immediately.

- Step C1.4. The DRM-AP computes $W^* = H(PW_{MU} || r^* || ID_{MU} || \sigma_{MU}^*)$, and then $K_{MU}^* = Y_{MU} \oplus W^*$.

- Step C1.5. The DRM-AP computes $DID_{DC} = ID_{DC} \oplus H(K_{MU}^* || T_{MU} || ID_{MU})$ for the selected digital content *DC*, which the user *MU* wants to access,

Mobile user (MU)	Public channel	License server (LS)
Inputs ID_{MU} and PW_{MU} . Imprints B_{MU}^* . Computes $\sigma_{MU}^* = Rep(B_{MU}^*, \tau_{MU})$, $r' = r^* \oplus H(\sigma_{MU}^* ID_{MU})$, $Z_{MU}^* = H(PW_{MU} r' \sigma_{MU}^*)$. Verifies $Z_{MU}^* = Z_{MU}$, computes $W^* = H(PW_{MU} r^* ID_{MU} \sigma_{MU}^*)$, $K_{MU}^* = Y_{MU} \oplus W^*$, $D = H(K_{MU}^* T_{MU} ID_{MU})$, $DID_{DC} = ID_{DC} \oplus D$, $C_1 = H(ID_{MU} ID_{DC} T_{MU} K_{MU}^*)$.	$\langle DID_{MU}, DID_{DC}, C_1, T_{MU} \rangle$	Verifies $ T'_{MU} - T_{MU} < \Delta T$. Computes $K_{MU} = H(ID_{MU} u X)$, $D = H(K_{MU} T_{MU} ID_{MU})$, $ID_{DC} = DID_{DC} \oplus D$. Verifies if $C_1 = H(ID_{MU} ID_{DC} T_{MU} K_{MU})$? Computes $C_2 = KEY_{ID_{DC}} \oplus H(ID_{MU} K_{MU} T_{LS} T_{MU})$, $C_3 = H(ID_{MU} K_{MU} T_{MU} T_{LS} KEY_{ID_{DC}})$.
Verifies $ T'_{LS} - T_{LS} < \Delta T$. Computes $KEY'_{ID_{DC}} = C_2 \oplus H(ID_{MU} K_{MU} T_{LS} T_{MU})$. Verifies if $C_3 = H(ID_{MU} K_{MU} T_{MU} T_{LS} KEY'_{ID_{DC}})$? Stores $KEY'_{ID_{DC}}$.	$\langle C_2, C_3, T_{LS} \rangle$	Stores $KEY_{ID_{DC}}$.

Figure 7. Summary of the content key acquisition phase.

where T_{MU} is the current timestamp used by DRM-AP.

- Step C1.6. The DRM-AP also computes $C_1 = H(\text{ID}_{MU} \parallel \text{ID}_{DC} \parallel T_{MU} \parallel K_{MU}^*)$.
- Step C1.7. The MU sends the log-in message $\langle \text{DID}_{MU}, \text{DID}_{DC}, C_1, T_{MU} \rangle$ to LS via a public channel.
- Step C2. Upon receiving the message $\langle \text{DID}_{MU}, \text{DID}_{DC}, C_1, T_{MU} \rangle$ at time T'_{MU} , LS does the following:
- Step C2.1. LS verifies the time delay in message transmission by checking the condition $|T'_{MU} - T_{MU}| < \Delta T$, where ΔT represents the maximum transmission delay or preset acceptable delay threshold. If it is valid, LS retrieves the user identity ID_{MU} and u as $(\text{ID}_{MU} \parallel u) = \text{Sym.Dec}_X(\text{DID}_{MU})$.
- Step C2.2. Then, LS computes $K_{MU} = H(\text{ID}_{MU} \parallel u \parallel X)$ and also retrieves ID_{DC} from DID_{DC} as $\text{ID}_{DC} = \text{DID}_{DC} \oplus H(K_{MU} \parallel T_{MU} \parallel \text{ID}_{MU})$.
- Step C2.3. LS verifies the condition $C_1 = H(\text{ID}_{MU} \parallel \text{ID}_{DC} \parallel T_{MU} \parallel K_{MU})$. If the verification succeeds, LS computes $C_2 = \text{KEY}_{\text{ID}_{DC}} \oplus H(\text{ID}_{MU} \parallel K_{MU} \parallel T_{LS} \parallel T_{MU})$ and $C_3 = H(\text{ID}_{MU} \parallel K_{MU} \parallel T_{MU} \parallel T_{LS} \parallel \text{KEY}_{\text{ID}_{DC}})$.
- Step C2.4. LS then sends the message $\langle C_2, C_3, T_{LS} \rangle$ to MU .
- Step C3. Upon receiving the message $\langle C_2, C_3, T_{LS} \rangle$ at time T'_{LS} , MU does the following:
- Step C3.1. MU verifies the time delay in message transmission by checking the condition $|T'_{LS} - T_{LS}| < \Delta T$. If the time delay in message transmission is valid, MU continues to compute $\text{KEY}'_{\text{ID}_{DC}} = C_2 \oplus H(\text{ID}_{MU} \parallel K_{MU} \parallel T_{LS} \parallel T_{MU})$.
- Step C3.2. MU then verifies the condition $C_3 = H(\text{ID}_{MU} \parallel K_{MU} \parallel T_{MU} \parallel T_{LS} \parallel \text{KEY}'_{\text{ID}_{DC}})$. If the verification fails, the session is terminated. Otherwise, the content key is authenticated.
- Step C3.3. MU can use the content key $\text{KEY}'_{\text{ID}_{DC}}$ to access the encrypted digital content $E(DC)$ in the future.

4.4. Password and biometric update phase

In this phase, the MU can change his or her password and personal biometrics because of security reasons without

further contacting the server LS . This phase contains the following steps:

- Step PB1. MU inputs his or her identity ID_{MU} and old password $\text{PW}_{MU}^{\text{old}}$ in the mobile device. After that, MU imprints the old biometrics B_{MU}^{old} at the sensor of the mobile device.
- Step PB2. The DRM-AP computes $\sigma_{MU}^{\text{old}} = \text{Rep}(B_{MU}^{\text{old}}, \tau_{MU})$ using the $\text{Rep}(\cdot)$ fuzzy extractor function and stores τ_{MU} in the mobile device.
- Step PB3. The DRM-AP further computes $r^{\text{old}} = r^* \oplus H(\sigma_{MU}^{\text{old}} \parallel \text{ID}_{MU})$, and then $Z_{MU}^{\text{old}} = H(\text{PW}_{MU}^{\text{old}} \parallel r^{\text{old}} \parallel \sigma_{MU}^{\text{old}})$.
- Step PB4. The DRM-AP checks the condition $Z_{MU}^{\text{old}} = Z_{MU}$. If it does not hold, the password and biometrics verification fails, and the phase is terminated immediately.
- Step PB5. The DRM-AP computes $W^{\text{old}} = H(\text{PW}_{MU}^{\text{old}} \parallel r^{\text{old}} \parallel \text{ID}_{MU} \parallel \sigma_{MU}^{\text{old}})$, and then $K_{MU}^{\text{old}} = Y_{MU} \oplus W^{\text{old}}$.
- Step PB6. MU inputs his or her new password $\text{PW}_{MU}^{\text{new}}$ and imprints new personal biometrics B_{MU}^{new} at the sensor of the mobile device. The DRM-AP computes $\text{Gen}(B_{MU}^{\text{new}}) = (\sigma_{MU}^{\text{new}}, \tau_{MU}^{\text{new}})$ and generates a random 1024-bit-large number r^{new} .
- Step PB7. The DRM-AP further computes $W^{\text{new}} = H(\text{PW}_{MU}^{\text{new}} \parallel r^{\text{new}} \parallel \text{ID}_{MU} \parallel \sigma_{MU}^{\text{new}})$ and $Y_{MU}^{\text{new}} = K_{MU}^{\text{old}} \oplus W^{\text{new}}$.
- Step PB8. Then, the DRM-AP computes $r^{**} = r^{\text{new}} \oplus H(\sigma_{MU}^{\text{new}} \parallel \text{ID}_{MU})$ and $Z_{MU}^{\text{new}} = H(\text{PW}_{MU}^{\text{new}} \parallel r^{\text{new}} \parallel \sigma_{MU}^{\text{new}})$.
- Step PB9. Finally, the DRM-AP updates the information Y_{MU} , Z_{MU} , r^* , and τ_{MU} with Y_{MU}^{new} , Z_{MU}^{new} , r^{**} , and τ_{MU}^{new} , respectively, in the mobile device.

The password and biometric update phase of our scheme is summarized in Figure 8.

5. SECURITY ANALYSIS OF THE PROPOSED SCHEME

In this section, we perform the security analysis of our scheme using both the formal and informal security analyses.

5.1. Authentication proof using the BAN logic

We apply the logical postulates of the most widely accepted BAN logic [36] to show the validity of authentication between the MU and the server. Using the BAN logic, we show that the MU and the server determine whether the exchanged information are secured and trustworthy

Mobile user (MU)	DRM-AP
Inputs ID_{MU} and PW_{MU}^{old} . Imprints B_{MU}^{old} .	Computes $\sigma_{MU}^{old} = Rep(B_{MU}^{old}, \tau_{MU})$, $r^{old} = r^* \oplus H(\sigma_{MU}^{old} ID_{MU})$, $Z_{MU}^{old} = H(PW_{MU}^{old} r^{old} \sigma_{MU}^{old})$. Verifies if $Z_{MU}^{old} = Z_{MU}$? Computes $W^{old} = h(PW_{MU}^{old} r^{old} ID_{MU} \sigma_{MU}^{old})$, $K_{MU}^{old} = Y_{MU} \oplus W^{old}$.
Inputs PW_{MU}^{new} , B_{MU}^{new} .	Computes $Gen(B_{MU}^{new}) = (\sigma_{MU}^{new}, \tau_{MU}^{new})$, $W^{new} = H(PW_{MU}^{new} r^{new} ID_{MU} \sigma_{MU}^{new})$, $Y_{MU}^{new} = K_{MU}^{old} \oplus W^{new}$, $r^{**} = r^{new} \oplus H(\sigma_{MU}^{new} ID_{MU})$, $Z_{MU}^{new} = H(PW_{MU}^{new} r^{new} \sigma_{MU}^{new})$. Replaces Y_{MU} , Z_{MU} , r^* and τ_{MU} with Y_{MU}^{new} , Z_{MU}^{new} , r^{**} and τ_{MU}^{new} , respectively.

Figure 8. Summary of the password and biometric update phase. DRM-AP, digital rights management-enable application.

against eavesdropping. This analysis is composed of the verification of message origin, message freshness, and the origin's trustworthiness. In order to describe logical postulates of BAN logic in formal terms, we present the following rules [36]:

Rule (1). Message-meaning rule: For the shared secret keys,

$$\frac{P \models Q \xleftrightarrow{K} P, P \triangleleft \{X\}_k}{P \models Q \sim X}.$$

If P believes that K is shared with Q and sees X encrypted under k , P believes that Q once said X .

Rule (2). Nonce verification rule:

$$\frac{P \models \sharp(X), P \models Q \sim X}{P \models Q \models X}.$$

If P believes that X has been uttered recently (freshness) and P believes that Q once said X , and then P believes that Q believes X .

Rule (3). Jurisdiction rule:

$$\frac{P \models Q \models X, P \models Q \Rightarrow X}{P \models X}.$$

If P believes that Q has jurisdiction over X , and P believes that Q believes a message X , P believes X .

Rule (4). Freshness rule:

$$\frac{P \models \sharp(X)}{P \models \sharp(X, Y)}.$$

If one part is known to be fresh, the entire formula must be fresh.

In the proposed scheme, the generic forms of the messages exchanged between the MU and the server are as follows:

Message 1. $U_i \rightarrow S : \langle \text{Sym.Enc}_X(ID_{MU} || u), DID_{DC}, C_1, T_{MU} \rangle$
Message 2. $S \rightarrow U_i : \langle C_2, C_3, T_{LS} \rangle$

In message 1, $DID_{DC} = ID_{DC} \oplus h(K_{MU} || T_{MU} || ID_{MU})$ and $C_1 = h(ID_{MU} || ID_{DC} || T_{MU} || K_{MU})$.

In message 2, $C_2 = KEY_{ID_{DC}} \oplus h(ID_{MU} || K_{MU} || T_{LS} || T_{MU})$ and $C_3 = h(ID_{MU} || K_{MU} || T_{MU} || KEY'_{ID_{DC}})$.

Subsequently, we translate the messages 1 and 2 into their idealize forms as follows:

Message 1. $MU \rightarrow LS : ID_{MU}, u_X, (ID_{MU}, ID_{DC}, T_{MU})_{K_{MU}}, T_{MU}$
Message 2. $LS \rightarrow MU : (ID_{MU}, T_{MU}, T_{LS}, KEY'_{ID_{DC}})_{K_{MU}}, T_{LS}$

Recall that in the proposed scheme, the MU and LS share a common secret key K_{MU} . Moreover, the MU and the server use the fresh timestamps. We make the following assumptions about the initial state of the proposed scheme:

$A_1: MU \models \sharp(T_{MU});$
 $A_2: LS \models \sharp(T_{LS});$
 $A_3: MU \models (MU \xleftrightarrow{K_{MU}} LS);$
 $A_4: LS \models (MU \xleftrightarrow{K_{MU}} LS);$
 $A_5: MU \models LS \models (MU \xleftrightarrow{K_{MU}} LS);$ and
 $A_6: LS \models MU \models (MU \xleftrightarrow{K_{MU}} LS).$

Lemma 1. The LS can correctly verify the authenticity of the MU's message.

Proof.

The MU generates a log-in message and sends to the server (LS) in order to log in to the server. With the message, the server receives the timestamp with other values, which help to prove the correctness of message source, as follows:

S_1 : According to message 1, we obtain $LS \triangleleft (ID_{MU}, ID_{DC}, T_{MU})_{K_{MU}}, T_{MU}$.
 S_2 : According to assumption A_4 , we apply the message-meaning rule to obtain $LS \models MU \sim T_{MU}$.

- S_3 : According to assumption A_1 , we apply the freshness-propagation rule to obtain $LS \equiv \#(ID_{MU}, ID_{DC}, T_{MU})_{K_{MU}}$.
- S_4 : According to S_2 and S_3 , we apply the timestamp verification rule and obtain $LS \equiv MU \equiv (ID_{MU}, ID_{DC}, T_{MU})_{K_{MU}}$.
- S_5 : According to assumption A_4 and S_4 , we apply the jurisdiction rule and obtain $LS \equiv T_{MU}$.

The server thus identifies that the used timestamp in the message is fresh. This proves the correctness of message source. $\square$

Lemma 2. *The MU can verify the correctness of responded message by the LS.*

Proof. In the proposed scheme, when the correctness of the MU's log-in message holds, the LS responds with a message, which includes the server's timestamp. The MU is able to identify the authenticity of server's message as follows:

- S_6 : According to message 2, we obtain $MU \triangleleft (ID_{MU}, T_{MU}, T_{LS}, KEY'_{ID_{DC}})_{K_{MU}}, T_{LS}$.
- S_7 : According to assumption A_3 , we apply the message-meaning rule to obtain $MU \equiv LS \sim T_{LS}$.
- S_8 : According to assumption A_2 , we apply the freshness concatenation rule to obtain $MU \equiv \#(ID_{MU}, T_{MU}, T_{LS}, KEY'_{ID_{DC}})_{K_{MU}}$.
- S_9 : According to S_7 and S_8 , we apply the timestamp verification rule to obtain $MU \equiv S \equiv (ID_{MU}, T_{MU}, T_{LS}, KEY'_{ID_{DC}})_{K_{MU}}$.
- S_{10} : According to assumption A_3 and S_9 , we apply the jurisdiction rule to obtain $MU \equiv T_{LS}$.

This shows that the MU can correctly verify the correctness of message source and its freshness. $\square$

Theorem 1. *The MU and LS can mutually authenticate each other.*

Proof. According to Lemma 1, the LS can correctly verify the log-in message authenticity. According to Lemma 2, the MU can also correctly verify the authenticity of LS's message. Thus, the MU and LS can correctly verify the authenticity of each other. As a result, the proposed scheme achieves mutual authentication. $\square$

5.2. Formal security analysis

In this section, we show that our scheme is secure through the formal security analysis under the random oracle model. We use the similar proof as in [37–40] for the formal security analysis. The method of contradiction

proof [41] is applied for our formal security analysis. Note that one can also prove the formal security in the standard model. However, in this paper, we perform the formal security analysis under the generic group model of cryptography.

For the formal security analysis, we first define the one-way hash function formally as follows:

Definition 2. *A collision-resistant one-way hash function $H : \{0, 1\}^* \rightarrow \{0, 1\}^l$ is a deterministic algorithm that takes an input of arbitrary-length binary string and outputs another binary string of fixed length l [42,43]. Let $Adv_A^{HASH}(t)$ denote an adversary A 's advantage in finding a collision. We then have $Adv_A^{HASH}(t) = Pr[(x, x') \leftarrow_R A : x \neq x', H(x) = H(x')]$, where $(x, x') \leftarrow_R A$ denotes that the pair (x, x') is selected randomly by A . Here, A is also allowed to be probabilistic, and the probability in the advantage is computed over the random choices made by A with the execution time t . We call $H(\cdot)$ is collision-resistant, if $Adv_A^{HASH}(t) \leq \psi$, for any sufficiently small $\psi > 0$.*

Algorithm 1 $EXP_{A, BEDRMS}^{HASH}$

- 1: Eavesdrop the message $(DID_{MU}, DID_{DC}, C_1, T_{MU})$ during the content key acquisition phase, where $DID_{MU} = \text{Sym.Enc}_X(ID_{MU} \| u)$, $K_{MU}^* = H(ID_{MU} \| u \| X)$, $D = H(K_{MU}^* \| T_{MU} \| ID_{MU})$, $DID_{DC} = ID_{DC} \oplus D$ and $C_1 = H(ID_{MU} \| ID_{DC} \| T_{MU} \| K_{MU}^*)$.
 - 2: Call RO oracle on input C_1 to retrieve the information ID_{MU}, ID_{DC}, T_{MU} and K_{MU}^* as $(ID'_{MU} \| ID'_{DC} \| T'_{MU} \| K'_{MU}) \leftarrow RO(C_1)$.
 - 3: **if** $T'_{MU} = T_{MU}$ **then**
 - 4: Compute $D' = H(K'_{MU} \| T'_{MU} \| ID'_{MU})$.
 - 5: Compute $ID_{DC}^* = DID_{DC} \oplus D'$.
 - 6: **if** $ID_{DC}^* = ID'_{DC}$ **then**
 - 7: Call RO oracle on input K'_{MU} to retrieve ID_{MU}, u , and X as $(ID''_{MU} \| u'' \| X'') \leftarrow RO(K'_{MU})$.
 - 8: Decrypt DID_{MU} using X'' to retrieve ID_{MU} and u as $(ID_{MU}^* \| u^*) = \text{Sym.Dec}_{X''}(DID_{MU})$.
 - 9: **if** $ID_{MU}^* = ID'_{MU}$ **then**
 - 10: Accept ID'_{MU}, ID'_{DC} and X'' as the correct ID_{MU} of MU , ID_{DC} of DC and the master key X of LS , respectively.
 - 11: **return** 1 (Success)
 - 12: **else**
 - 13: **return** 0 (Failure)
 - 14: **end if**
 - 15: **else**
 - 16: **return** 0 (Failure)
 - 17: **end if**
 - 18: **else**
 - 19: **return** 0 (Failure)
 - 20: **end if**
-

To apply the method of contradiction proof [41], we assume that the following random oracle exists for an adversary, say $\mathcal{A}$:

- RO : It is a random oracle, which will unconditionally output the input string x from the corresponding hash value $y = H(x)$.

Theorem 2. *Under the assumption that a one-way hash function $H(\cdot)$ closely behaves like a random oracle, our scheme is secure against an adversary for deriving the identity ID_{MU} of the mobile user MU , the identity ID_{DC} of the digital content DC , and the master key X of the license server LS .*

Proof. The proof of this theorem is similar to that in [37–40]. In this proof, we construct an adversary $\mathcal{A}$, who will have the ability to derive correctly ID_{MU} , ID_{DC} , and X . $\mathcal{A}$ can run the algorithm $EXP_{\mathcal{A}, BEDRMS}^{HASH}$ for our biometric-based enterprise DRM system (BEDRMS), provided in Algorithm 1, which uses the RO oracle. The success probability for $EXP_{\mathcal{A}, BEDRMS}^{HASH}$ is given by $Succ = |Pr[EXP_{\mathcal{A}, BEDRMS}^{HASH} = 1] - 1|$, where $Pr[E]$ is the probability of an event E . The advantage function for this experiment is then $Adv(t, q_{RO}) = \max_{\mathcal{A}} \{Succ\}$, where the maximum has taken over all $\mathcal{A}$ with execution time t and the number of queries q_{RO} made to RO oracle. Our scheme is secure against $\mathcal{A}$ for deriving ID_{MU} of MU , ID_{DC} of DC , and the master key X of LS , if $Adv(t, q_{RO}) \leq \epsilon$, for any sufficiently small $\epsilon > 0$.

If we consider the experiment $EXP_{\mathcal{A}, BEDRMS}^{HASH}$, then according to this, the adversary $\mathcal{A}$ can derive ID_{MU} , ID_{DC} and X if he or she has the ability to invert a one-way hash function $H(\cdot)$, and win the game using the RO oracle. However, it is a contradiction from Definition 2 that it is a computationally hard problem for $\mathcal{A}$, since $Adv_{\mathcal{A}}^{HASH}(t) \leq \psi$. Clearly, $Adv(t, q_{RO})$ in $EXP_{\mathcal{A}, BEDRMS}^{HASH}$ depends on $Adv_{\mathcal{A}}^{HASH}(t)$ as the experiment uses RO oracle. As a result, we have $Adv(t, q_{RO}) \leq \epsilon$, for any sufficiently small $\epsilon > 0$. Hence, our scheme is secure against an adversary for deriving ID_{MU} , ID_{DC} , and X . $\square$

5.3. Informal security analysis

In this section, we show that the proposed scheme satisfies other security requirements, which are discussed in the succeeding text.

5.3.1. User anonymity.

In the proposed scheme, the log-in message includes the MU dynamic identity DID_{MU} , where $DID_{MU} = \text{Sym.Enc}_X(ID_{MU} || u)$. An adversary cannot retrieve ID_{MU} from DID_{MU} as the user's identity ID_{MU} is protected with the server's secret key X . Moreover, the adversary cannot guess the identity ID_{MU} as it is concatenated with a random number r . This shows that the proposed scheme provides user anonymity property.

5.3.2. Stolen-verifier attack.

In the proposed scheme, the server does not store the MU -related information in its database. Even the server does not include the MU 's identity and registration time. So, the proposed scheme prevents the stolen verifier attack.

5.3.3. Stolen mobile device attack.

An adversary can extract the stored parameters Y_{MU} and DID_{MU} from the stolen mobile device. However, to retrieve the MU 's identity ID_{MU} from DID_{MU} , the server's secret key X is needed. To retrieve the user's secret key K_{MU} from Y_{MU} , both the user's password PW_{MU} and identity ID_{MU} are needed as $Y_{MU} = K_{MU} \oplus W$ and $W = H(PW_{MU} || r || ID_{MU} || \sigma_{MU})$. The identity ID_{MU} and password PW_{MU} are the parameters, which the MU needs to memorize, not store them. Therefore, an adversary cannot achieve the user's secret key K_{MU} . This shows that an adversary cannot retrieve any useful information from the stolen mobile device.

5.3.4. Off-line password-guessing attack.

An adversary can use the values C_1 and C_3 to verify the guessed password, where $C_1 = H(ID_{MU} || T_{MU} || K_{MU})$ and $C_3 = H(ID_{MU} || K_{MU} || T_{MU} || KEY_{ID_{DC}})$ from the transmitted messages during the content key acquisition phase. However, to verify the guessed password using C_1 and C_3 , the MU identity ID_{MU} and the secret key K_{MU} are needed. K_{MU} is protected with $W = H(PW_{MU} || r || ID_{MU} || \sigma_{MU})$, and to compute σ_{MU} , the MU biometrics B_{MU} is needed. As the MU 's identity ID_{MU} is protected with the server's secret key X , the adversary cannot achieve ID_{MU} . Additionally, only a legal mobile user MU can imprint B_{MU} . This proves that the proposed scheme resists the password-guessing attack.

5.3.5. Replay attack.

In the proposed scheme, both the log-in and responder messages during the log-in and content key acquisition phases include the current timestamps, where an MU and the server verify the time delay in message transmissions. The timestamp is uniquely selected for each session. The uniqueness property of the timestamp restricts the repetition of the log-in messages. This shows that the proposed scheme resists replay attack.

5.3.6. Mutual authentication.

In the mutual authentication mechanism, an MU must prove its identity to the server, and also, the server must prove its identity to that user (MU). In the proposed scheme, both the user MU and the server authenticate each other. To achieve this, the user MU and the server verify the conditions $C_1 = H(ID_{MU} || T_{MU} || K_{MU})$ and $C_3 = H(ID_{MU} || K_{MU} || T_{MU} || KEY_{ID_{DC}})$, respectively. To compute C_1 and C_3 , the MU identity ID_{MU} and secret key of the server X are needed. As only the user and the server can compute C_1 and C_3 , the server can verify the user authenticity and vice versa. As a result, our scheme achieves the mutual authentication.

6. FORMAL SECURITY VERIFICATION OF THE PROPOSED SCHEME USING AVISPA TOOL

In this section, we simulate our proposed scheme for formal security verification using the widely accepted AVISPA tool [37–40,44–46].

AVISPA is a widely accepted powerful tool that provides a modular and expressive formal language for specifying protocols and their security properties, and integrates different back ends that implement a variety of state-of-the-art automatic analysis techniques [37–40,44–46]. AVISPA contains four back ends, which are given in the following:

- On-the-fly Model Checker (OFMC): This back end does several symbolic techniques to explore the state space in a demand-driven way [45].
- Constraint-Logic-based Attack Searcher (CL-AtSe): This back end does a translation from any security protocol specification written as transition relation in intermediate format into a set of constraints, which are effectively used to find whether there are attacks on protocols.
- Satisfiability Problems in Propositional Logic (SAT)-based Model Checker: It builds a propositional formula, and after that, it is fed to a state-of-the-art SAT solver, and any model found is translated back into an attack.
- Tree Automata based on Automatic Approximations for the Analysis of Security Protocols: This back end approximates the intruder knowledge by using regular tree languages.

Protocols need to be specified in High-Level Protocols Specification Language (HLPSL) [47] for the implementation in roles. Each specified role is independent from other roles, which obtain some initial information by parameters, and then communicates with the other roles by channels. HLPSL is translated by the HLPSL2IF translator in order to produce the intermediate format (IF). The IF is then fed to one of four back ends, which produces the output format. When the analysis of a protocol has been successful (by finding an attack or not), the output describes precisely what is the result, and under what conditions it has been obtained. The output format has several sections, which are described as follows:

- SUMMARY indicates whether the tested protocol is safe, unsafe, or whether the analysis is inconclusive.
- DETAILS either explains under what condition the tested protocol is declared safe, or what conditions have been used for finding an attack, or finally why the analysis was inconclusive.
- PROTOCOL, GOAL, and BACKEND are the name of the protocol, the goal of the analysis, and the name of the back end used, respectively.

- Finally, after some comments and statistics, the trace of an attack (if any) is also printed in the standard Alice–Bob format.

Some of the basic types are discussed in the following for specifying our scheme in HLPSL ([46,47]):

- *agent*: It represents the principal names. The intruder is always assumed to have the special identifier *i*.
- *public_key*: This type represents agents' public keys in a public-key cryptosystem. For example, given a public (respectively private) key *KU*, its inverse private (respectively public) key is obtained by *inv_KU*.
- *symmetric_key*: This type represents the keys for a symmetric-key cryptosystem.
- *text*: These values can be used for messages. If *N* is of type *text* (*fresh*), then *N'* will be a fresh value, which the intruder cannot guess.
- *nat*: It represents the natural numbers in non-message contexts.
- *const*: It represents constants.
- *hash_func*: The base type *hash_func* represents cryptographic hash functions. The base-type function also represents functions on the space of messages. It is assumed that the intruder cannot invert hash functions (in essence, that they are one-way collision-resistant functions).
- *channel(dy)*: It represents that the channel is insecure, and it is for the Dolev–Yao model [28] (as in our threat model) with the possibility for the intruder to assume a legitimate role in a protocol run.

The space of legal messages is defined as the closure of the basic types. For a given message *M* and encryption key *K*, $\{M\}_K$ is referred to as the symmetric/public-key encryption. We use “.” operator to always denote the concatenations. More details on AVISPA and HLPSL can be found in [45–47].

6.1. Specifying our scheme

In our implementation, we have two basic roles: *mobile user* and *server*, which represent the participants as a legal mobile user *MU* and the server *S*, respectively. The specification in HLPSL for the role of *MU* is shown in Figure 9. During the registration phase, *U_i* first receives the start signal and changes its state from 0 to 1, and then sends registration request message $\langle ID_{MU}, W \rangle$ to the server *S*(*LS*) via a secure channel using the *SEND()* operation. In response, *MU* receives the message $\langle Y_{MU} DID_{MU} \rangle$ from the server *S* using the *RECV()* operation. The declaration *secret*($\{PW_{mu}, B_{mu}\}$, subs1, *MU*) indicates that the password PW_{MU} and biometrics B_{MU} of the mobile user *MU* are kept secret permanently to *MU* characterized by the protocol identifier subs1, similarly for other declarations characterized by the protocol IDs subs2, subs3, and subs4. During the content key acquisition phase, *MU*

```

role user (MU, S : agent,
% MU: mobile user; S: LS or PS (server)
% symmetric key between MU and S
  SKmus : symmetric_key,
% H is hash function
  H : hash_func,
  SEND, RECV: channel(dy))
played_by MU
def=
local State : nat,
  IDmu, IDdc, PWmu, Bmu, Tmu, Tls : text,
  R, U, W, DIDmu, Kmu, Ymu, X, KEYdc : text,
  Gen, Rep : hash_func

const subs1, subs2, subs3, subs4, user_server_r,
  user_server_tmu, server_user_u,
  server_user_tls : protocol_id
init State := 0
transition
% Registration phase
1. State = 0  $\wedge$  RECV(start) =>
% Send the registration message to LS securely
State' := 1  $\wedge$  R' := new()
   $\wedge$  W' := H(PWmu.R'.IDmu.Gen(Bmu))
   $\wedge$  secret({PWmu,Bmu}, subs1, MU)
   $\wedge$  secret(IDmu, subs2, {MU, S})
   $\wedge$  SEND({IDmu.W'}_SKmus)
% MU has freshly generated the value r for LS
   $\wedge$  witness(MU, S, user_server_r, R')
% Receive the message <Ymu, DIDmu > from LS
2. State = 1  $\wedge$  RECV(xor(H(IDmu.U'.X), H(PWmu.R'.IDmu.Gen(Bmu))).{IDmu.U'}_X) =>
% Authorization phase
% Send the message <DIDmu, DIDdc, C1, Tmu > to LS
State' := 2  $\wedge$  Tmu' := new()
   $\wedge$  SEND({IDmu.U'}_X. xor(IDdc,H(H(IDmu.R'.X).Tmu'.IDmu)).H(IDmu.IDdc.Tmu'.H(IDmu.R'.X)).Tmu')
% MU has freshly generated the value Tmu for LS
   $\wedge$  witness(MU, S, user_server_tmu, Tmu')
% Receive the message <C2, C3, Tls > from LS
3. State = 2  $\wedge$  RECV(xor(KEYdc,H(IDmu.H(IDmu.R'.X).Tls'.Tmu')).H(IDmu.H(IDmu.R'.X).Tmu'.Tls'.KEYdc).Tls') =>
% MU's acceptance of the value u generated for MU by LS
State' := 3  $\wedge$  request(S, MU, server_user_u, U)
% MU's acceptance of the value Tls generated for MU by LS
   $\wedge$  request(S, MU, server_user_tls, Tls')
end role

```

Figure 9. Role specification in High-Level Protocols Specification Language for the mobile user *MU*.

sends the log-in message $\langle DID_{MU}, DID_{DC}, C_1, T_{MU} \rangle$ to the server *LS*. In response, *MU* receives the message $\langle C_2, C_3, T_{LS} \rangle$ from *LS*. The “played_by *A*” declaration indicates that the agent named in variable *A* will play in a specific role. A knowledge declaration (generally in the top-level *Environment* role) is used to specify the intruder’s initial knowledge. Immediate reaction transitions have the form $X = 1 > Y$, which relate an event *X* and an action *Y*, and it indicates that whenever we take a transition that is labeled in such a way as to make the event predicate *X* true, we must immediately (that is, simultaneously) execute action *Y*. If a variable *V* needs to be permanently a secret, it is expressed by the goal *secrecy_of V*. Therefore, if *V* is ever obtained or derived by the intruder, a security violation will result. The declaration witness(*MU*,

```

role server (MU, S : agent,
% MU: mobile user; S: LS or PS (server)
% symmetric key between MU and S
  SKmus : symmetric_key,
% H is hash function
  H : hash_func,
  SEND, RECV: channel(dy))
played_by S
def=
local State : nat,
  IDmu, IDdc, PWmu, Bmu, Tmu, Tls : text,
  R, U, W, DIDmu, Ymu, Kmu, X, KEYdc : text,
  Gen, Rep : hash_func

const subs1, subs2, subs3, subs4, user_server_r,
  user_server_tmu, server_user_u,
  server_user_tls : protocol_id
init State := 0
transition
% Registration phase
% Receive the registration request from user MU securely
1. State = 0  $\wedge$  RECV({IDmu.H(PWmu.R'.IDmu.Gen(Bmu))}_SKmus) =>
State' := 1  $\wedge$  U' := new()
   $\wedge$  Kmu' := H(IDmu.U'.X)
   $\wedge$  Ymu' := xor(Kmu', H(PWmu.R'.IDmu.Gen(Bmu)))
   $\wedge$  DIDmu' := {IDmu.U'}_X
   $\wedge$  secret(X, subs3, S)
% Send the message <Ymu, DIDmu > to MU
   $\wedge$  SEND(Ymu'.DIDmu')
% LS has freshly generated the value u for MU
   $\wedge$  witness(S, MU, server_user_u, U')
% Authorization phase
% Receive the message <DIDmu, DIDdc, C1, Tmu > from MU
2. State = 1  $\wedge$  RECV({IDmu.U'}_X. xor(IDdc,H(H(IDmu.R'.X).Tmu'.IDmu)).H(IDmu.IDdc.Tmu'.H(IDmu.R'.X)).Tmu') =>
% Send the message <C2, C3, Tls > to MU
State' := 2  $\wedge$  Tls' := new()
   $\wedge$  secret(KEYdc, subs4, S)
   $\wedge$  SEND(xor(KEYdc,H(IDmu.H(IDmu.R'.X).Tls'.Tmu')).H(IDmu.H(IDmu.R'.X).Tmu'.Tls'.KEYdc).Tls')
% LS has freshly generated the value Tls for MU
   $\wedge$  witness(S, MU, server_user_tls, Tls')
% LS's acceptance of the value r generated for LS by MU
   $\wedge$  request(MU, S, user_server_r, R')
% LS's acceptance of the value Tmu generated for LS by MU
   $\wedge$  request(MU, S, user_server_tmu, Tmu')
end role

```

Figure 10. Role specification in High-Level Protocols Specification Language for the server.

S, *user_server_tmu*, *Tmu'*) tells that *MU* has freshly generated the value T_{MU} for the server *LS*. The declaration request(*S*, *MU*, *server_user_tls*, *Tls'*) indicates that *MU*’s acceptance of the value T_{LS} generated for *MU* by the server *LS*, that is, the user *MU* authenticates the server *LS* based on the received timestamp T_{LS} in the message. Similarly, we have specified the HLPSSL implementation for the role of the server *LS* in Figure 10.

In Figure 11, we have implemented the specifications in HLPSSL for the roles of session, goal, and environment. In the session segment, all the basic roles including the roles for *MU* and *LS* are instantiated with concrete arguments. The top-level role (environment) defines in the specification of HLPSSL, which contains the global constants and a composition of one or more sessions, where an intruder (always denoted by *i*) may play some roles as legitimate users as specified in the environment role. In


```

role session(MU, S : agent,
             SKmus : symmetric_key,
             H : hash_func)
def=
  local S1, S2, R1, R2: channel (dy)
composition
  user (MU, S, SKmus, H, S1, R1)
 $\wedge$  server (MU, S, SKmus, H, S2, R2)
end role

role environment()
def=
  const mu, s: agent, skmus : symmetric_key,
        h : hash_func, gen, rep : hash_func,
        tmu, tls : text,
        subs1, subs2, subs3, subs4, user_server_r,
        user_server_tmu, server_user_u,
        server_user_tls : protocol_id
intruder_knowledge = {mu, s, h, gen, rep, tmu, tls}
composition
  session(mu, s, skmus, h)
 $\wedge$  session(mu, s, skmus, h)
 $\wedge$  session(mu, i, skmus, h)
 $\wedge$  session(i, s, skmus, h)
end role

goal
  secrecy_of subs1
  secrecy_of subs2
  secrecy_of subs3
  secrecy_of subs4

  authentication_on user_server_r
  authentication_on user_server_tmu
  authentication_on server_user_u
  authentication_on server_user_tls
end goal
environment()

```

Figure 11. Role specification in High-Level Protocols Specification Language for the session, and the goal and environment of our scheme.

HLPSSL, the intruder (*i*) can also participate in the execution of protocol as a concrete session. Note that the current version of HLPSSL supports the standard authentication and secrecy goals. In our implementation, we have verified the four secrecy goals, and four authentications are verified. For example, secrecy_of subs1 represents that the password PW_{MU} and biometrics B_{MU} are kept secret to the mobile user MU only. The declaration authentication_on server_user_tls indicates LS generates a current timestamp T_{LS} , and if the mobile user MU receives T_{LS} from the received messages from LS , MU authenticates LS based on T_{LS} .

```

% OFMC
% Version of 2006/02/13
SUMMARY
SAFE
DETAILS
BOUNDED_NUMBER_OF_SESSIONS
PROTOCOL
/home/avispa/web-interface-computation/
./tempdir/workfilekxB7eQ.if
GOAL
as_specified
BACKEND
OFMC
COMMENTS
STATISTICS
parseTime: 0.00s
searchTime: 0.68s
visitedNodes: 146 nodes
depth: 6 plies

```

Figure 12. The result of the analysis using On-the-fly Model Checker (OFMC) back end.

6.2. Simulation results

We have simulated our scheme under the OFMC and CL-AtSe back ends using the AVISPA web tool [48]. We have chosen OFMC back end for an execution test and a bounded number of sessions model checking [45]. We have also chosen CL-AtSe back end for an execution test in order to verify the formal security of our scheme. The simulation results are shown in Figures 12 and 13.

The following verifications in our scheme are performed as in [44,49]:

- Executability check on nontrivial HLPSSL specifications: Because of some modeling mistakes, the protocol model cannot sometimes execute to completion. The back ends of AVISPA tool may not be able to find an attack, if the protocol model cannot reach to a state where that attack can happen. An executability test is thus very essential [47]. Our executability check shows that the protocol description is well matched with the designed goals as specified in Figures 9–11.
- Replay attack check: For this check, the back ends verify whether the legitimate agents can execute the specified protocol by performing a search of a passive intruder. The back ends then give the intruder the knowledge of some normal sessions between the legitimate agents. The test results shown in Figures 12 and 13 ensure that our scheme is secure against the replay attack.

SUMMARY

SAFE

DETAILS

BOUNDED_NUMBER_OF_SESSIONS

TYPED_MODEL

PROTOCOL/home/avispa/web-interface-computation/
./tempdir/workfilekB7eQ.if**GOAL**

As Specified

BACKEND

CL-AtSe

STATISTICSAnalysed : 275 states
Reachable : 211 states
Translation: 0.02 seconds
Computation: 0.16 seconds**Figure 13.** The result of the analysis using Constraint-Logic-based Attack Searcher (CL-AtSe) back end.

- Dolev–Yao model check: For this check, the back ends also check if there is any man-in-the-middle attack possible by the intruder. In OFMC back end, the depth for the search is six, and output of the results is shown in Figure 12; 146 nodes have been searched in 0.68 s. It is evident from the results that our scheme fulfills the design properties and it is secure under the test of AVISPA using OFMC back end with the bounded number of sessions. Moreover, for CL-AtSe back end test in Figure 13, 211 states are reachable out of total 275 analyzed states, which take 0.02 and 0.16 s for the translation and computation, respectively. From the results under CL-AtSe back end, it is also evident that our scheme is secure.

In summary, the test results using both OFMC and CL-AtSe back ends ensure that our scheme is secure against the replay and man-in-the-middle attacks.

7. PERFORMANCE COMPARISON WITH RELATED SCHEMES

In this section, we show the performance of our proposed scheme with the related E-DRM schemes [17–19] for

the mobile environment. We do not consider the schemes [20,22] for the performance comparison as those schemes are based on group key distribution protocol.

In Table II, we have compared the communication cost in terms of the total number of transmitted messages as well as bits of our scheme with that for other existing schemes [17–19] during authorization and license acquisition phase. We assume that the hash digest (output) is 160 bits, if we use SHA-1 hash function [50]. The timestamp, i , $msgreq$, user identity, content identity, anonymous identity, and IMEI are 32 bits each. The digital certificate $Cert$ of the mobile user MU in Chen's scheme [17] and Chang *et al.*'s scheme [18] is assumed to have $|Cert|$ bits depending on which certificate is being used. We take 1024-bit RSA cryptosystem [51] for the public-key encryption/decryption and digital signature purpose, and DES algorithm [52] for symmetric encryption/decryption so that the plaintext and ciphertext messages are 64 bits each. In our scheme, during the content key acquisition phase, the message $\langle DID_{MU}, DID_{DC}, C_1, T_{MU} \rangle$ requires $(64 + 160 + 160 + 32) = 416$ bits and the message $\langle C_2, C_3, T_{LS} \rangle$ requires $(160 + 160 + 32) = 352$ bits. As a result, our scheme needs $(416 + 352) = 768$ bits for the communication overhead of two transmitted messages. In Chang *et al.*'s scheme [19], during the authorization phase, three messages $\langle i, msgreq, T_{MU}, ID_{DC}, P_{MU_i}, C_{MU_i}, AID, IMEI \rangle$, $\langle ID_{DC}, AID, IMEI, T_{AA}, P_{AA_i}, CAA_i \rangle$, and $\langle AID, P_{LS_i}, C_{LS_i}, T_{LS} \rangle$ require $(32 + 32 + 32 + 32 + 160 + 160 + 32 + 32) = 512$, $(32 + 32 + 32 + 32 + 160 + 160) = 448$, $(32 + 160 + 160 + 32) = 384$ bits, respectively. Thus, the total communication overhead in this scheme is $(512 + 448 + 384) = 1344$ bits. On the other hand, during the authorization phase, Chen's scheme [17] and Chang *et al.*'s scheme [18] need $2400 + 2|Cert|$ bits and $2240 + 2|Cert|$ bits for the transmission of four messages, respectively. From this table, it is clear that our scheme

Table II. Communication overhead comparison between our scheme and other schemes.

Scheme	Communication overhead
Chen [17]	Four messages (2400 + 2 Cert bits)
Chang <i>et al.</i> [18]	Four messages (2240 + 2 Cert bits)
Chang <i>et al.</i> [19]	Three messages (1344 bits)
Ours	Two messages (768 bits)

Table III. Comparison of computational speeds among cryptographic primitives [19,53].

Operation	Number of operations per second
Public key Cryptosystem (1024-bit RSA)	20
Symmetric encryption/decryption (DES)	2000
One-way hash function (MD5/SHA-1)	20,000

requires minimum communication overheads as compared with that for other schemes [17–19].

Comparison of computational speeds among various cryptographic primitives is shown in Table III [19,53]. From this table, it is clear that one-way hash function (MD5/SHA) and symmetric key DES encryption/decryption are much efficient than 1024-bit RSA public-key cryptosystem. In Table IV, the computation overhead of our scheme is compared with that for the other related existing schemes during all the phases, namely packaging, registration, and authorization (content key acquisition) phases. Let T_h , T_{pub} , T_{sym} , T_{fe} , and T_X denote the time complexity for computation of a one-way hash function $H(\cdot)$, a public-key encryption/decryption/digital signature, a symmetric encryption/decryption, a fuzzy extractor ($Gen(\cdot)$ function or $Rep(\cdot)$ function), and XOR operation, respectively. It is well known that the time complexity of bitwise XOR operation is negligible as compared with other operations. So, we do not take T_X into account in computation cost comparison. It is noted that the public-key encryption/decryption/digital signature

(e.g., RSA encryption/decryption or signature [51]) is the most expensive operation as compared with other operations like one-way hash function, symmetric-key encryption/decryption, and fuzzy extractor ($Gen(\cdot)$ and $Rep(\cdot)$ functions) [35]. The total computation costs required for Chen's scheme [17], Chang *et al.*'s scheme [18], and Chang *et al.*'s scheme [19] are respectively $(8|F(\cdot)| + 6)T_h + 2T_{sym} + 7T_{pub}$, $(6|F(\cdot)| + 4)T_h + 2T_{sym} + 7T_{pub}$, and $14T_h + 2T_{sym} + 6T_{pub}$. On the other hand, our scheme needs the computation cost $2T_{fe} + 16T_h + 4T_{sym} + 2T_{pub}$. Because our scheme requires less number of public-key operations, our scheme is efficient in computation as compared with other schemes [17–19].

Finally, in Table V, we compare the functionality of our scheme with other E-DRM schemes. Note that the existing schemes in [17] and [18] require the certificate management and do not protect user anonymity. An adversary can easily know the consumer content preferences and can reveal their selection for the personal benefit, which leads to a violation of the user's privacy rights. To overcome the certificate management, Chang *et al.*'s scheme [18]

Table IV. Computation cost comparison of E-DRM schemes.

Scheme	Phase	Mobile user side	Server(s) side	Total cost
Chen [17]	Package	–	$T_{sym} + 5T_{pub}$	
	Registration	–	–	
	Authorization	$(5 F(\cdot) + 3)T_h + T_{sym}$	$(3 F(\cdot) + 3)T_h + 2T_{pub}$	$(8 F(\cdot) + 6)T_h + 2T_{sym} + 7T_{pub}$
Chang <i>et al.</i> [18]	Package	–	$T_{sym} + 5T_{pub}$	
	Registration	–	–	
	Authorization	$(3 F(\cdot) + 2)T_h + T_{sym}$	$(3 F(\cdot) + 2)T_h + 2T_{pub}$	$(6 F(\cdot) + 4)T_h + 2T_{sym} + 7T_{pub}$
Chang <i>et al.</i> [19]	Package	–	$T_{sym} + 6T_{pub}$	
	Registration	–	$2T_h$	$14T_h + 2T_{sym}$
	Authorization	$4T_h + T_{sym}$	$8T_h$	$+6T_{pub}$
Ours	Package	–	$T_{sym} + 2T_{pub}$	
	Registration	$T_{fe} + 3T_h$	$T_h + T_{sym}$	$2T_{fe} + 16T_h$
	Content key acquisition	$T_{fe} + 7T_h + T_{sym}$	$5T_h + T_{sym}$	$+4T_{sym} + 2T_{pub}$

$F(\cdot)$: a one-way hash function as in [17] and [18].

E-DRM: enterprise digital rights management.

Table V. Security attributes comparison of E-DRM schemes.

Scheme/Attribute	UA	IA	CMR	PGA	MMA	SDA	RA	RC	PBU
Chen [17]	No	Yes	Yes	N/A	No	Yes	Yes	Yes	No
Chang <i>et al.</i> [18]	No	Yes	Yes	N/A	Yes	Yes	Yes	No	No
Chang <i>et al.</i> [19]	Yes	No	No	No	Yes	No	Yes	No	No
Ours	Yes	Yes	No	Yes	Yes	Yes	Yes	No	Yes

UA: whether provides user anonymity or not; IA: whether protects insider attack or not; CMR: whether certificate management is required or not; PGA: whether prevents off-line password-guessing attack or not; MMA: whether protects man-in-the middle attack or not; SDA: whether resilient against stolen device attack or not; RA: where protects replay attack or not; RC: whether requires redundant computation or not; PBU: whether supports efficient password and biometric update phase or not; E-DRM, enterprise digital rights management.

presented an anonymous ID-based E-DRM scheme. Their scheme enhances the efficiency and provides the user's anonymity. However, it does not resist the insider attack and off-line password-guessing attack. Moreover, it reveals the consumer preference in the key distribution to an adversary as the user messages include the content identity. On the other hand, our scheme preserves the consumer preference from an adversary and resists the password-guessing attack as well as insider attack. In addition, our scheme keeps the low computation overhead and ID-based authentication as in Chang *et al.*'s scheme [18]. Furthermore, our scheme supports an additional feature, which is the password and biometric update phase by the MU locally without further contacting the server.

8. CONCLUSION AND FUTURE WORKS

We have discussed the merits and demerits of the existing E-DRM schemes in the literature. The analysis indicates that the existing schemes are either vulnerable to known attacks or they do not protect user's anonymity. We have analyzed the security of recently proposed efficient and anonymous E-DRM scheme of Chang *et al.* suitable for the mobile environment. We have identified that an adversary can successfully perform the off-line password-guessing attack and insider attack on Chang *et al.*'s scheme. In addition, their scheme has design flaws in the authorization phase. The cryptanalysis of Chang *et al.*'s scheme thus shows that the security of their scheme is compromised. In order to overcome the security weaknesses of Chang *et al.*'s scheme, we have then presented a secure and efficient content distribution scheme for the E-DRM system suitable for mobile environment. The proposed scheme supports mutual authentication and key agreement where a user can correctly identify the source and establish a secure session key. The proposed scheme protects user's anonymity and satisfies the other desirable security attributes. The rigorous formal and informal security analyses show that our scheme is secure. In addition, our scheme is computationally efficient when compared with the other existing schemes.

The client-server-based E-DRM is gradually replaced by the cloud-based E-DRM [24–27]. Petrlic and Sorge [27] also pointed that a DRM system is crucial for the software providers to take part in the future cloud computing. In future, we like to extend our work presented in this paper for the cloud-based E-DRM so that we can further optimize the computation and communication costs while maintaining the same level of security.

ACKNOWLEDGEMENTS

We would like to acknowledge the many helpful suggestions of the anonymous reviewers and the editor of this Journal.

REFERENCES

1. Subramanya SR, Yi BK. Digital rights management. *IEEE Potentials* 2006; **25**(2): 31–34.
2. Ku W, Chi C. Survey on the technological aspects of digital rights management. In *Information Security, Lecture Notes in Computer Science, LNCS*, Vol. 3225. Springer: Berlin Heidelberg, 2004; 391–403.
3. Rosset V, Filippin C, Westphall C. A DRM architecture to distribute and protect digital contents using digital licenses. *Proceedings of Advanced Industrial Conference on Telecommunications/Service Assurance With Partial and Intermittent Resources Conference/E-learning on Telecommunications Workshop (Telecommunications 2005)*, 2005; 422–427.
4. Yo Y, Chiueh T. Enterprise digital rights management: solutions against information theft by insiders. RPE report, September 2004. Available at www.ecsl.cs.sunysb.edu/tr/rpe-drm-yy.pdf. [Accessed on February 2015].
5. Digital Rights Management. *IEEE Emerging Technology portal, 2006-2012*. Available at http://www.ieee.org/about/technologies/emerging/digital_rights.pdf. [Accessed on February 2015].
6. Kaspersky lab Internal IT Threats in Europe 2006. Available at <http://www.viruslist.com/en/analysis/pubid=204791935>. [Accessed on November 2014].
7. Zeng W, Liu K. Sensitivity analysis of loss of corporate efficiency and productivity associated with enterprise DRM technology. *2012 Seventh International Conference on Availability, Reliability and Security (ARES)*, University of Economics in Prague, Czech Republic, 2012; 445–453.
8. Burke BE, Christiansen CA. Insider risk management: a framework approach to internal security. *RSA, The Security Division of EMC*, 2009.
9. Zeng W, Van Moorsel A. Quantitative evaluation of enterprise DRM technology. *Electronic Notes in Theoretical Computer Science* 2011; **275**: 159–174.
10. Adobe Lifecycle Document Security (2009). Available at http://www.adobe.com/content/dam/Adobe/en/devnet/lifecycle/pdfs/rm_security_tg.pdf. [Accessed on November 2014].
11. Venkataramu R. Analysis and enhancement of Apple's FairPlay digital rights management 2007.
12. Bradley D, Josang A. Mesmerize: an open framework for enterprise security management. *Proceedings of the Second Workshop on Australasian Information Security, Data Mining and Web Intelligence, and Software Internationalisation-Volume 32*, Australian Computer Society Inc., Dunedin, New Zealand, 2004; 37–42.

13. Authentica Delivers Next-Generation Enterprise Rights Management Platform (2005). Available at <http://www.authentica.com/news/pr2005/02-14-2005-ARM.aspx> [Accessed on November 2014].
14. Microsoft Windows Right Management Services System (2007). Available at <http://technet.microsoft.com/en-us/magazine/2006.10.howitworks.aspx> [Accessed on November 2014].
15. Van Wie DM, Weber RP. Steganographic techniques for securely delivering electronic digital rights management control information over insecure communication channels 1999, US Patent 5,943,422.
16. Dambrowski J. Intertrust's Role in Information Assurance for Digital Media 2003.
17. Chen CL. A secure and traceable E-DRM system based on mobile device. *Expert Systems with Applications* 2008; **35**(3): 878–886.
18. Chang CC, Yang JH, Wang DW. An efficient and reliable E-DRM scheme for mobile environments. *Expert Systems with Applications* 2010; **37**(9): 6176–6181.
19. Chang CC, Chang SC, Yang JH. A practical secure and efficient enterprise digital rights management mechanism suitable for mobile environment. *Security and Communication Networks* 2013; **6**(8): 972–984.
20. Guo C, Chang CC. An authenticated group key distribution protocol based on the generalized Chinese remainder theorem. *International Journal of Communication Systems* 2014; **27**(1): 126–134.
21. Fraenkel AS. New proof of the generalized Chinese remainder theorem. *Proceedings of the American Mathematical Society* 1963; **14**(5): 790–791.
22. Liu Y, Chang C C, Chang S C. A group key distribution system based on the generalized Aryabhata remainder theorem for enterprise digital rights management. *Journal of Information Hiding and Multimedia Signal Processing* 2015; **6**(1): 140–153.
23. Chang CC, Yeh JS, Yang JH. Generalized Aryabhata remainder theorem. *International Journal of Innovative Computing, Information and Control* 2010; **6**(4): 1865–1871.
24. Huang Q L, Yang Y, Fu J, Niu X. Secure and privacy-preserving DRM scheme using homomorphic encryption in cloud computing. *The Journal of China Universities of Posts and Telecommunications* 2013; **20**(6): 88–95.
25. Zou P, Wang C, Liu Z, Bao D. Phosphor: a cloud based DRM scheme with SIM Card, 2010; 459–463.
26. Wang C, Zou P, Liu Z, Wang J. CS-DRM: a cloud-based SIM DRM scheme for mobile Internet. *EURASIP Journal on Wireless Communications and Networking* 2011; **2011**: 1–19, Article ID 837209. DOI: 10.1155/2011/837209.
27. Petric R, Sorge C. Privacy-preserving DRM for cloud computing. *26th International Conference on Advanced Information Networking and Applications Workshops (WAINA)*, IEEE, Fukuoka, Japan, 2012; 1286–1291.
28. Dolev D, Yao AC. On the security of public key protocols. *IEEE Transactions on Information Theory* 1983; **29**(2): 198–208.
29. Jain AK, Ross A, Prabhakar S. An introduction to biometric recognition. *IEEE Transactions on Circuits and Systems for Video Technology* 2003; **14**(1): 4–20.
30. Prabhakar S, Pankanti S, Jain AK. Biometric recognition: security and privacy concerns. *IEEE Security Privacy Magazine* 2003; **1**(2): 33–42.
31. Ratha N, Karu K, Chen S, Jain A. A real-time matching system for large fingerprint databases. *IEEE Transactions on Pattern Analysis and Machine Intelligence* 1996; **18**(8): 799–813.
32. Li CT, Hwang MS. An efficient biometric-based remote user authentication scheme using smart cards. *Journal of Network and Computer Applications* 2010; **33**: 1–5.
33. Dodis Y, Reyzin L, Smith A. Fuzzy extractors: how to generate strong keys from biometrics and other noisy data. *Advances in Cryptology - EUROCRYPT 2004, Lecture Notes in Computer Science*, vol. 3027, Springer, Berlin Heidelberg, 2004; 523–540.
34. Burnett A, Byrne F, Dowling T, Duffy A. A biometric identity based signature scheme. *International Journal of Network Security* 2007; **5**(3): 317–326.
35. He D, Kumar N, Lee J H, Sherratt R. Enhanced three-factor security protocol for consumer USB mass storage devices. *IEEE Transactions on Consumer Electronics* 2014; **60**(1): 30–37.
36. Burrows M, Abadi M, Needham R. A logic of authentication. *ACM Transactions on Computer Systems* 1990; **8**(1): 18–36.
37. Odelu V, Das AK, Goswami A. A secure and efficient ECC-based user anonymity preserving single sign-on scheme for distributed computer networks. *Security and Communication Networks* 2014. DOI: 10.1002/sec.1139.
38. Chatterjee S, Das AK. An effective ECC-based user access control scheme with attribute-based encryption for wireless sensor networks. *Security and Communication Networks* 2014. DOI: 10.1002/sec.1140.
39. Mishra D, Das AK, Mukhopadhyay S. A secure user anonymity-preserving biometric-based multi-server authenticated key agreement scheme using smart cards. *Expert Systems with Applications* 2014; **41**(18): 8129–8143.
40. Mishra D, Das AK, Mukhopadhyay S. A secure and efficient ECC-based user anonymity-preserving

- session initiation authentication protocol using smart card. *Peer-to-Peer Networking and Applications* 2014, DOI: 10.1007/s12083-014-0321-z.
41. Chuang YH, Tseng YM. An efficient dynamic group key agreement protocol for imbalanced wireless networks. *International Journal of Network Management* 2010; **20**(4): 167–180.
 42. Sarkar P. A simple and generic construction of authenticated encryption with associated data. *ACM Transactions on Information and System Security* 2010; **13**(4): 33.
 43. Stinson DR. Some observations on the theory of cryptographic hash functions. *Designs, Codes and Cryptography* 2006; **38**(2): 259–277.
 44. Lv C, Ma M, Li H, Ma J, Zhang Y. An novel three-party authenticated key exchange protocol using one-time key. *Journal of Network and Computer Applications* 2013; **36**(1): 498–503.
 45. Basin D, Modersheim S, Vigano L. OFMC. A symbolic model checker for security protocols. *International Journal of Information Security* 2005; **4**(3): 181–208.
 46. Automated Validation of Internet Security Protocols and Applications. Available at: <http://www.avispa-project.org/package/usermanual.pdf> [Accessed on March 2013].
 47. von Oheimb D. The high-level protocol specification language HLPSL developed in the EU project AVISPA, 2005; 1–17.
 48. Automated validation of internet security protocols and applications AVISPA Web Tool. Available at <http://www.avispa-project.org/web-interface/expert.php/> [Accessed on October 2014].
 49. Das AK. An efficient and novel three-factor user authentication scheme for large-scale heterogeneous wireless sensor networks. *International Journal of Communication Networks and Distributed Systems* 2015, In press.
 50. FIPS PUB 180-1 National Institute of Standards and Technology (NIST). U.S. Department of Commerce, April 1995. Accessed on November 2010.
 51. Rivest RL, Shamir A, Adleman LM. A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM* 1978; **21**(2): 120–126.
 52. Stallings W. *Cryptography and Network Security: Principles and Practices*, 3rd edn. Pearson Education: India, 2003.
 53. Schneier B. *Applied Cryptography, Protocols, Algorithms, and Source Code in C*, 2nd edn. John Wiley and Sons Inc: New York, U.S.A, 1996. 15.